BearingPoint

Global Management & Technology Consulting

FINANCIAL SERVICES TECHNOLOGY JOURNAL

SPRING 2005 | VOLUME 2 | ISSUE 1

THE RISK, COMPLIANCE AND SECURITY ISSUE

Letter From the Executive Editor 1

This Issue at a Glance 2

The Business of Technology

How to Create a Holistic Risk and Compliance Framework

Part I: Building the Data and Workflow Infrastructure 5

Part II: Integrating Systems, Processes and Tools 16

How It (Should) All Start

Risk and Identity Management for Financial Services 22

Designing and Implementing a Continuity of Operations Solution for Financial Services Firms 29

Data for Decision

Using Real Options to Mitigate Risks in Large IT Projects 34

Monte Carlo Analysis for Technology Project Risk Modeling 41

Below the Code

Data Security, Privacy, Integrity and Compliance 46

Infrastructure Implications of the Convergence of Risk and Compliance 52

Contributors 58

A periodic publication exploring the finer points of topics relevant to the financial services industry

LETTER FROM THE EXECUTIVE EDITOR

Welcome to the risk, compliance and security issue of *Financial Services Technology Journal*.

Recently, one of my colleagues described to me what some view as being the big issue in compliance right now. In his words, here is what some clients are asking for: *"Give me really good brakes and a heads-up display and a helmet so I can drive as fast as I can, push as much product through the pipe as I can, and have the tools to know when to slow down. In short, give me the mechanisms so that I don't drive over the cliff—for example, find my name in the paper, get fined three hundred million dollars or get a letter from the office of the attorney general."*

Another equally colorful way at looking at the emergence of risk, compliance and security (RCS) management is as a major theme of the century using the TLA (three-letter acronym) paradigm so in vogue nowadays, it looks like the RCS trifecta is really a new form of FUD (fear, uncertainty and doubt). But should the FUD factor alone be driving the industry? Sure, dealing with fear, uncertainty and doubt *is* a unifying theme when discussing risk, compliance and security. But while the FUD factor might be driving so many marketing initiatives targeted at information technology buyers ("*Protect yourself against <insert risk here>, buy <insert risk solution here>*!"), it does not mean that technologists should lose sight of what constitutes stronger and more useful linkages between the risk, compliance and security domains. The fact is, managing RCS often requires leveraging the same kind of data and monitoring the same processes across the three domains.

Indeed, over the last few years, market issues have increased business risk factors, and these, along with expanding regulatory requirements, are compelling financial institutions and their technologists to look at the convergence of key processes and the sharing of data that serve risk mitigation, regulatory compliance and security management.

So, our hypothesis is that one of the key trends in financial services today is the convergence of RCS management. As a result, we believe that financial services organizations and their technologists should chart their journey toward this convergence, and as such we decided to explore this journey thoroughly with this issue. Risk, compliance and security management are part of a larger continuum that requires financial services organizations to consider a range of issues, from financial management to business continuity planning. This idea has significant consequences for IT planners. From a technology standpoint, it means that financial services technologists need to look at all these initiatives using a holistic, portfolio-based approach and implement point solutions to satisfy immediate business needs while looking for architecture convergence opportunities as the business domains they support converge.

As with all our previous issues, we want to continue bringing you ideas, data and insights on these topics in a way that puts technology in a true business context. The convergence of RCS management is so broad that we needed and brought together a large team of guides in our expedition (12 of them!). In many cases, we had to examine issues from different perspectives (for example, from a process, application and technology infrastructure standpoint). That made for interesting discussions to put together the eight articles in this issue, the largest and most ambitious to date. The result is that you'll have more companions on your journey. And you won't have to don a funny hat as you get near a cliff.

The BearingPoint professionals who contribute their insights here are eager to know how well they are doing. We encourage you to offer feedback and ideas for future topics to Pierre Pureur, the journal's editor, and our team at FSTechJournalEditors@bearingpoint.com.

Manuel Barbero
Executive Editor, BearingPoint's *Financial Services Technology Journal*

THIS ISSUE AT A GLANCE

By Pierre Pureur, editor, BearingPoint's *Financial Services Technology Journal*

SUMMARY

This issue is expansive. So large, in fact, that we thought it would be useful to include a summary to guide you through the material. We organized the articles using a framework that we prototyped in our first two publications and continue to use in this issue:

- **The Business of Technology** explores how technologies create and deliver business value. This section contains the introductory articles "How to Create a Holistic Risk and Compliance Framework" Parts I and II.
- **How It (Should) All Start** examines the new approaches to strategy and architecture that are shaping the information technology world. In this section, we explore some of the disciplines that make the convergence of risk, security and compliance management possible.
- **Data for Decision** delves into data and models needed for informed decision making, with a focus on risk modeling using real options and Monte Carlo analysis.
- **Below the Code** brings you best practices and observations on networking, computing infrastructure and other technology realms, offered in a way that navigates between news release hype and the "tech-talk" that only hardcore techies can love.

HOW TO CREATE A HOLISTIC RISK AND COMPLIANCE FRAMEWORK

PART I: BUILDING THE DATA AND WORKFLOW INFRASTRUCTURE

Manuel Barbero, Jeff Brashear, Sean Culbert, Paul Dunay and Brian Hart

The worlds of risk, compliance and security management are converging now in much the same way risk management and finance have over the past few years. This convergence involves (or takes place across) multiple domains. It is triggered by the demand to manage purely financial risk and compliance requirements that are dictated by government regulations, and it extends across the continuum to purely operational requirements created both by regulations and market forces.

Each of these domains is at a different stage of its life cycle, so financial services companies are fortunate to be able to address them with a staggered approach. But, overall, a portfolio approach to dealing with risk, compliance (and security) is in order.

This article presents a unifying framework that decomposes the problem space into a series of individual domains; projects the path along which these domains may evolve in the next three to five years, particularly with regard to how and where the relevant reference data may be managed; and discusses how technologists should build the technology infrastructure needed to support the digitization of the risk and compliance value chain.

PART II: INTEGRATING SYSTEMS, PROCESSES AND TOOLS

Manuel Barbero, Jeff Brashear, Antonio Castro and Sean Culbert

Financial services organizations are undertaking an array of compliance initiatives in response to discrete regulatory mandates such as the Sarbanes-Oxley Act and Basel II.

Institutions can improve compliance enterprisewide by bringing these efforts into a holistic compliance framework.

Such a framework facilitates taking the right actions at the right time in response to, or in anticipation of, compliance-related events. Rather than requiring

new systems and technology, the holistic compliance framework leverages the existing, sizable investment institutions have made in compliance systems and technology.

This article builds on the previous one by discussing how to link key applications into a workflow framework on top of the technology risk and compliance infrastructure proposed in the introductory article.

RISK AND IDENTITY MANAGEMENT FOR FINANCIAL SERVICES

Alex Berson

The global connectivity provided by the Internet has allowed organizations to network easily with their customers, suppliers and business partners. However, by moving the boundaries of an enterprise away from the corporate headquarters, the Internet has created a new set of security challenges.

These include threats that either did not exist before or have become much more serious and complex because of the ease of access and "virtual close proximity," not only for welcome participants, such as customers, partners and suppliers, but for unwelcome intruders and hackers.

Customer identity management (CIM) works in concert with customer relationship management (CRM), information security and risk management to satisfy customer expectations while protecting the interests of the enterprise.

This article provides a general introduction to the drivers of CIM and the key constructs associated with CIM. It also presents a reference architecture that technologists can use to help implement identity management as a core component of their systems.

DESIGNING AND IMPLEMENTING A CONTINUITY OF OPERATIONS SOLUTION FOR FINANCIAL SERVICES FIRMS

Steve Timmons

The existence of a comprehensive business continuity or enterprise organizational survival plan can be a way to mitigate operational risk and thus is an element of Basel II.

In addition, the need for a good business continuity or enterprise organizational survival plan for compliance systems now also stems from the fact that regulators demand and expect a very short response time when they issue requests for documentation.

Many elements must come together for a financial services firm to respond effectively to emergencies, maintain continuity of operations and recover from an event. The Organizational Survival Planning (OSP) model provides the framework for a comprehensive approach to crisis events.

Through the OSP, firms can set an organizational survival strategic vision and develop comprehensive plans for organizational awareness and training, model crisis communication, and address the human factor in crises. This article presents key concepts associated with OSP.

USING REAL OPTIONS TO MITIGATE RISKS IN LARGE IT PROJECTS

Pierre Pureur

In an environment of uncertainty, real option techniques contribute to an understanding of growth options. Such techniques identify how to proceed in the case of initial project success and how best to abandon a project should it become unprofitable.

Each information technology investment can be associated with a portfolio

of real options. Thus, these techniques offer a valuable tool for evaluating IT investment projects under uncertain conditions.

This article outlines an approach to leveraging a strong financial analysis technique, actually pervasive within financial services organizations—real options valuation—to help build solid business cases for IT investments in general and IT implementations in particular, while mitigating the risks associated with those investments.

MONTE CARLO ANALYSIS FOR TECHNOLOGY PROJECT RISK MODELING

Manuel Barbero, Daryouche Behboudi, Antonio Castro and Julien Courbe

Estimating the likely cost of an information technology project with many parameters or potential risks is a crucial but difficult exercise. Use of probability-based techniques can facilitate the process, yet many technologists are disinclined to use them.

This article provides a quick primer on Monte Carlo analysis (MCA), a technique that provides a visual representation of risk distribution and a practical approach to costing out IT projects.

The article draws on real-life examples of applying MCA to large-scale IT implementations and provides a practical approach to using it to cost out IT projects based on real-life case studies, such as the deployment of a new branch network or Voice over Internet Protocol.

DATA SECURITY, PRIVACY, INTEGRITY AND COMPLIANCE

Alex Berson

The Internet has brought about an information and connectivity revolution. Enterprises, governments and individuals all now act as participants in a globally interconnected, networked ecosphere in which all participants originate, process and receive information. The information assets available in this networked ecosphere continue to grow, expanding its scope and increasing security threats.

The networked ecosphere and the information it contains have become attractive targets for malicious attacks, information theft and other security threats. Sensitive data needs to be protected from unauthorized access and use. This need is emphasized by a number of regulatory and compliance requirements, some of which are general, others specific to the financial services.

This article focuses on the specifics of data security from an application viewpoint.

INFRASTRUCTURE IMPLICATIONS OF THE CONVERGENCE OF RISK AND COMPLIANCE

Gerry Rossi

Because the information describing many of an enterprise's business dealings resides within its infrastructure as data, the capabilities of that infrastructure go a long way toward defining the firm's capabilities in the risk and compliance area.

Regulatory agencies increasingly focus on requiring firms to safeguard new data types beyond basic transactions, and safeguarding no longer means only preservation; it also means prevention of inappropriate distribution. Since technology continues to change rapidly, the ability of a firm's infrastructure to preserve data has improved, but the number of ways data can be distributed in an uncontrolled manner is rising.

Technologists must address these new challenges in an integrated way. This article focuses on the specifics of data security from an infrastructure viewpoint.■

The Business of Technology

How to Create a Holistic Risk and Compliance Framework

Part I: Building the Data and Workflow Infrastructure

Abstract

The worlds of risk, compliance and security management are converging now in much the same way risk management and finance have over the past few years. This convergence involves (or takes place across) multiple domains. It is triggered by the demand to manage purely financial risk and compliance requirements that are dictated by government regulations, and it extends across the continuum to purely operational requirements created both by regulations and market forces.

Each of these domains is at a different stage of its life cycle, so financial services companies are fortunate to be able to address them with a staggered approach. But, overall, a portfolio approach to dealing with risk, compliance and security is in order.

This article presents a unifying framework that decomposes the problem space into a series of individual domains; projects the path along which these domains will evolve in the next three to five years, particularly with regard to how and where the relevant reference data will be managed; and discusses how technologists should build the technology infrastructure needed to support the digitization of the risk and compliance value chain. A companion article—"How to Create a Holistic Risk and Compliance Framework Part II: Integrating Systems, Processes and Tools"—then discusses how to link key applications into a workflow framework that exposes audit events.

Recognizing the Risk and Compliance Management Continuum

In recent months, the financial services business community has begun to recognize increasing convergence between risk management and compliance management issues. Increasing business risk factors stemming from a host of market issues, along with expanding regulatory requirements, are compelling financial institutions and their technologists to look at the convergence of key processes and data that serves both risk management and regulatory compliance.

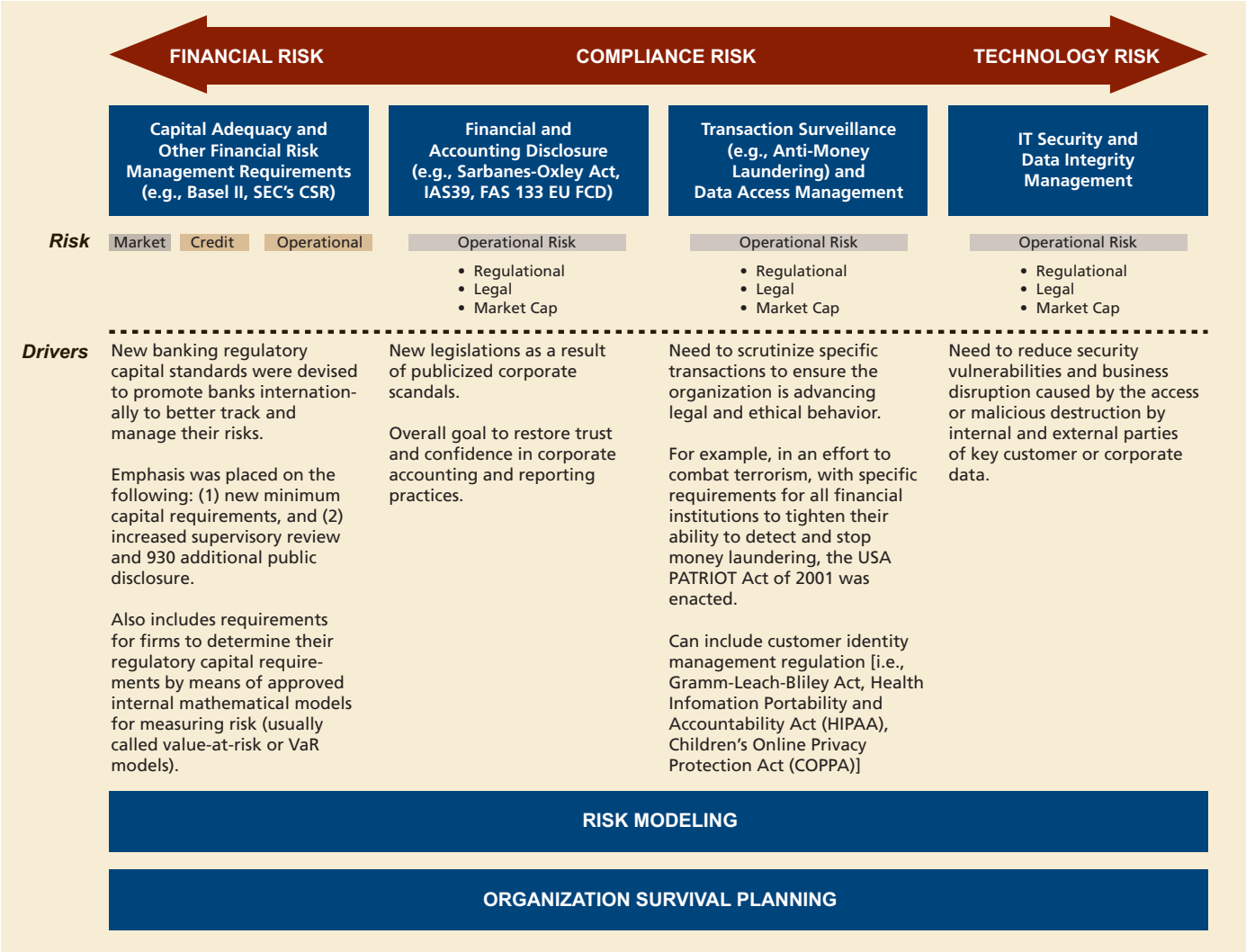
This convergence is similar to that which in the previous years has fused the finance and risk management worlds.[1] So the convergence of risk and compliance management is itself a part of a larger risk and compliance management continuum that encompasses everything from financial reporting and market and credit risk to information security and business continuity (see Figure 1).

The continuum depicts several risk and compliance domains, from purely financial reporting issues across the continuum to purely operational issues (for example, at the front-office level), with several domains in between. For example:

- The capital adequacy and financial risk management domain deals with internal reporting and external disclosure of financial risk and compliance information, with consequences that extend to reputational and legal. These include the market, credit and operational risks associated with the Basel II Accord and anti-money laundering (AML) legislation.
- Toward the middle of the continuum are domains that have financial aspects but are more operational and compliance-oriented in nature.
- On the far right side of the continuum are risk and compliance issues associated with the pure information technology operations—how to secure enterprise data, including customer and trading partner data, and how to ensure the continuity of the business in a high-risk era of human and natural disasters.
- Underpinning the four central domains is a fifth—enterprise survival planning. Problems that can erupt in any one of the domains across the con-

[1]See "How Compliance Has Changed the Finance Department—Forever," by M. Sullivan, available at *www.bearingpoint.com/compliance.*

Figure 1: The Risk and Compliance Management Continuum



tinuum can create catastrophic situations in other domains.

A final item added to this framework is risk modeling. We believe risk modeling is an essential technique for technologists, particularly their ability to forecast and manage IT risks.[2]

Overlaps occur between these domains. For example, companies must disclose material events under Sarbanes-Oxley Section 409, but they must also report such events under operational risk rules of the Basel II Accord. Further, market, credit and operational risk disclosures under Pillar III of the accord are subject to the rigors of Sarbanes-Oxley legislation, and the controls associated with the reporting infrastructure (people, process and technology) are subject to Section 404. We would also argue that the self-assessment processes devised as a part of Sarbanes-Oxley implementation are the starting points for many organizations in devising self-assessment processes for Basel II.

This cause-and-effect dynamic leads to two key conclusions:

- Financial services companies should examine all of their risk and compliance domains from a portfolio perspective. This does not imply that risk and

[2]See "Using Real Options to Mitigate Risks in Large IT Projects" by P. Pureur and "Monte Carlo Analysis for Technology Project Risk Modeling" by M. Barbero, et. al, in the Data for Decision section of this issue.

compliance are exclusively a matter of technology, but they are two domains in which the use of technology is paramount.

- Financial services technologists should consider and implement point solutions as needed now but keep the convergence of architecture as a key objective for the medium- and long-term future. This is especially true given that, as we will see, the data used across risk, finance and compliance is so similar.

THE FOUR ISSUES TECHNOLOGISTS NEED TO ADDRESS

The consequence for the technology community is clear: IT strategists, planners and operational managers need to familiarize themselves with the range of issues, tools and technologies relevant to each domain in the framework presented in Figure 1. We present other elements of this framework in articles and case studies throughout this issue to give financial services technologists an idea of what they will face in the coming years. A firm understanding of each domain is a tall order. This said, from a pragmatic standpoint, the core challenges that technologists will have to address going forward boil down to a manageable set of four:

1. Determining true convergence priorities and their IT effects.
2. Assessing the impact of the convergence in terms of complexity and how to manage it.
3. Defining a plausible end-state compliance architecture.
4. Incorporating enterprise survival planning considerations, such as security and business continuity management, into the overall convergence planning process.

We explore each of these issues in the rest of this article.

WHAT ARE THE REAL PRIORITIES? UNDERSTANDING THE RISK LIFE CYCLE

As we consider the convergence issues, it's important to understand that all risk and compliance management requirements have life cycles and, therefore, can be prioritized in terms of the current level of concern the organization should have about them (see Figure 2).

For example, there is no question that many, though not all, financial services businesses are, and have been, dealing with market risk, so this is a very mature area of risk and compliance. AML is another mature area that companies can address by deploying point solutions, which is precisely what financial organizations have been doing for more than 24 months now.

In other domains, however, issues are still evolving. For example, commercial lenders are fully capable of defining credit risk for individual clients and individual products, but very few have developed a real-time ability to view their exposure

Figure 2: The Risk and Compliance Life Cycle

[3]For an example of a workflow-based approach to managing credit risk across product lines in the context of commercial lending, see "Enterprise Credit Management, Digitization Comes of Age" by S. Coyle, et. al, in the December 2004 issue of the *Financial Services Technology Journal*, available at *www.bearingpoint.com/ecm*.

across multiple product lines—for example, custody, commercial banking and clearing—for a specific client.[3]

The situation with Sarbanes-Oxley is equally muddy. Most organizations have documented key, mostly manual, internal control processes in a way that addresses the concerns specified by Section 404 of the act. We refer to this as having addressed the Sarbanes-Oxley *assurance* challenge.

However, very few organizations have taken the next step and translated this one-time effort into a repeatable, digitized process by deploying workflow tools. We call this the Sarbanes-Oxley *automation* challenge.

By addressing the automation challenge, financial institutions will take compliance with Section 404 to a new level by ensuring that these and many other processes are demonstrably traceable. Adherence to Section 409 of the act is even more difficult, due in part to the wide range of issues that it raises.

MANAGING COMPLEXITY—FOLLOWING THE DATA IS A PRAGMATIC APPROACH

With these examples in view, it's clear that not every risk and compliance management issue or domain is hitting financial institutions and technologists at the same time. Consequently, technologists can breathe a sigh of relief because they have the opportunity to take a staggered approach to the multitude of issues they will face in the next few years.

Traditionally, technologists deal with complexity by defining a somewhat idealized end state and then working their way back to the present. They then analyze the gap between a set of target objectives embodied in the end-state definition and the current state to develop an overall architectural road map.

This said, when we examine the challenges at hand, we can see that the issues technologists face in dealing with risk and compliance are similar to those that we described in our last issue of the *Financial Services Technology Journal*—the digitization of the financial services value chain. Fundamentally, what we are discussing is the *digitization of the risk and compliance value chain*.

Not surprisingly, then, a number of the themes we present here echo those we presented in the last issue, including leveraging a host of techniques ranging from portal technologies, digital content management, workflow, business intelligence, collaboration, information life cycle management, and enterprise information integration tools and techniques[4] on top of the data management architecture approach presented in this section.

From a technology standpoint, a realistic approach to digitizing the compliance chain should encompass two types of domains:

- **Infrastructure.** What kind of communication and data sharing or transformation tools are needed to support the digitization of the risk and compliance value chain?
- **Process and applications.** What kind of process and business and technology services must exist, and how should systems be modified, in order to link information and enforce policies? In other words, how do you link key applications into a workflow framework that audits and controls cross-application activities and exposes audit events?

Once the essential supporting "piping" has been built, technologists can focus on implementing the process and business and technology services needed to implement the rest of the compliance framework.

The result is a holistic compliance framework that connects existing systems using document management, business process management, business rules engines and business activity monitoring (BAM) systems. We address building a BAM system in the next article, "How to Create a Holistic Risk and Compliance Framework Part II: Integrating Systems, Processes and Tools."

From an infrastructure standpoint, probably the most important issues to be considered are the location of and interaction between key repositories of data. This section will focus on this issue first: planning the evolution of the overall data architecture at the enterprise level is critical, particularly in terms of costs.[5]

Often, people make this discussion overly complex. Yet in the end, the interaction and data flows among four types of systems are at the heart of data convergence. These include:

- General ledger system(s) set up to manage the enterprise financial records with every transaction flowing through them.
- Source systems, which typically include market data feeds, credit and rating engines, and transaction sys-

[4] See "Digitization: The Time is Here" by R. Walker and P. Dunay in the December 2004 issue of the *Financial Services Technology Journal*, available at *www.bearingpoint.com/digi.*

[5] For a cost-impact analysis on the surprising lack of data integration and data standards to provide a foundation for risk management and financial transparency, see "Global Risk Study Reveals Reactionary Overspending and Duplication of Efforts on Compliance Impedes Overall Growth," a BearingPoint study at *www.bearingpoint.com/riskstudy.*

tems—among many others—all generating real-time transaction or market data at various levels of granularity. Some are needed to record accounting events at the highest level of precision, typically at the general ledger level, or a lower level of detail, such as those required for Basel II reporting. These systems also include subsidiary ledgers for items such as cash, accounts receivable and accounts payable. Entries that are posted to these subledgers are eventually transacted through the general ledger account.

- Management reporting systems, which provide the typical reports and dashboards required to generate Generally Accepted Accounting Principles (GAAP) financial reports and management reports that depict the financial performance of the enterprise, and other data required by management to run the organization, such as cost data for allocations.
- Risk and compliance management systems, which are relatively new, are usually point solutions that enterprises have had to deploy or are deploying now to address immediate regulatory and compliance demands.

Fundamentally, developing an architectural evolutionary path requires answering the following questions, which we have attempted to do provisionally. As financial institutions answer each question and implement the associated architecture, they will move from one "plateau" to another over the next three to five years (see Figures 3, 4 and 5).

***Q:** With regard to risk management alone, should we implement point solutions, such as those required now to address the provisions of AML or Basel II regulations?*

A: In most cases, technologists have no choice but to implement point solutions—risk and compliance management systems with data fed into implementation-specific silo data marts

Figure 3: Evolution of the Risk Management Architecture, Plateau I

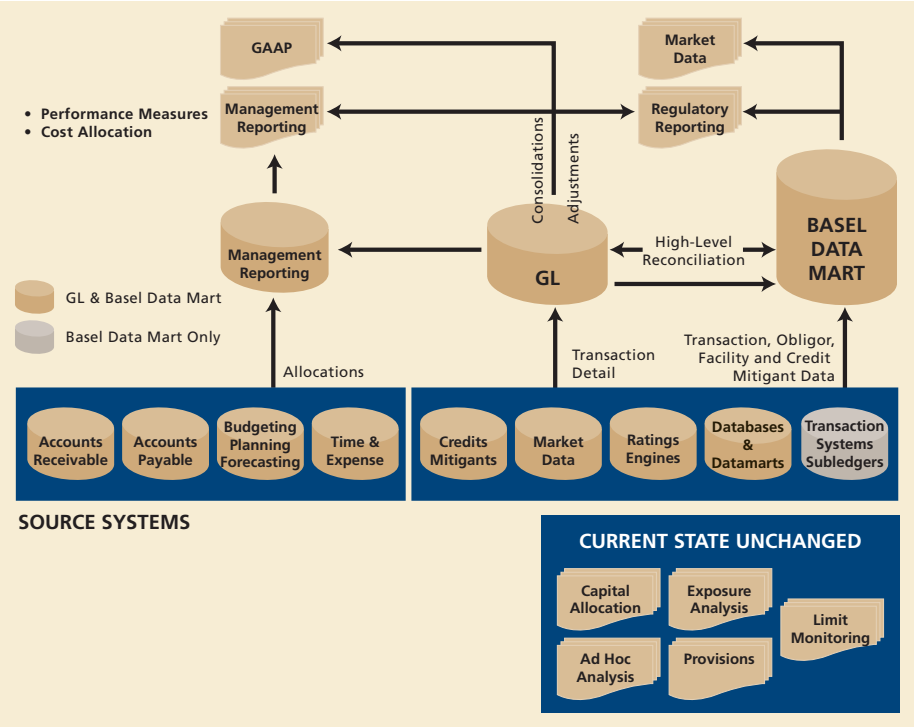
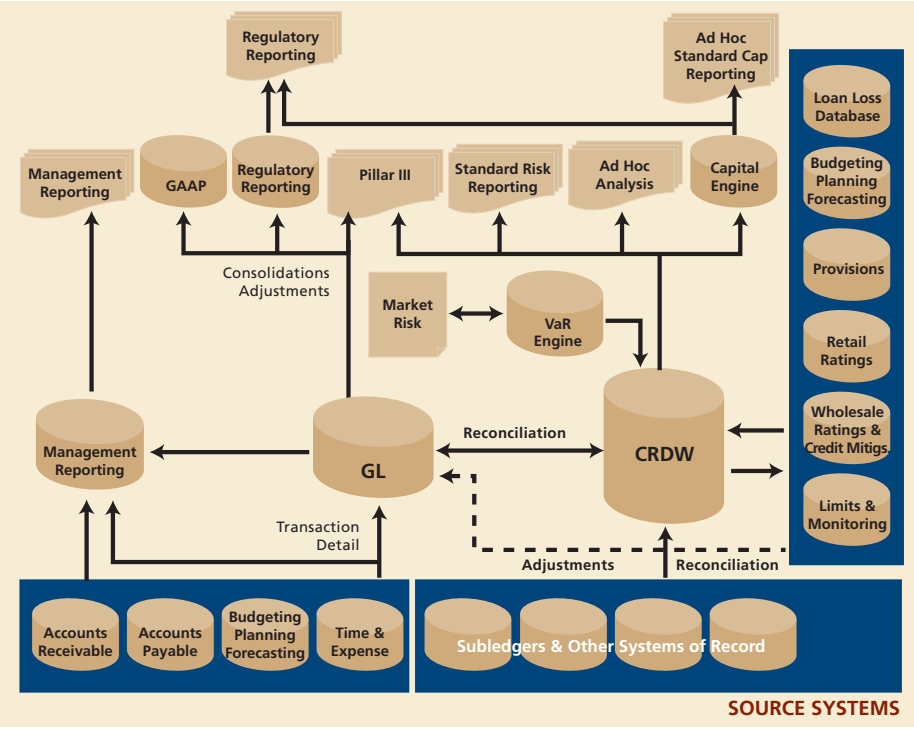


Figure 4: Evolution of the Risk Management Architecture, Plateau II



that need to be synched up periodically or in real time with both the general ledger and various source systems. The resulting architecture is what many companies have now, depicted as Plateau I in Figure 3.

***Q:** When and how can we realize economies of scale and scope across these risk management systems?*

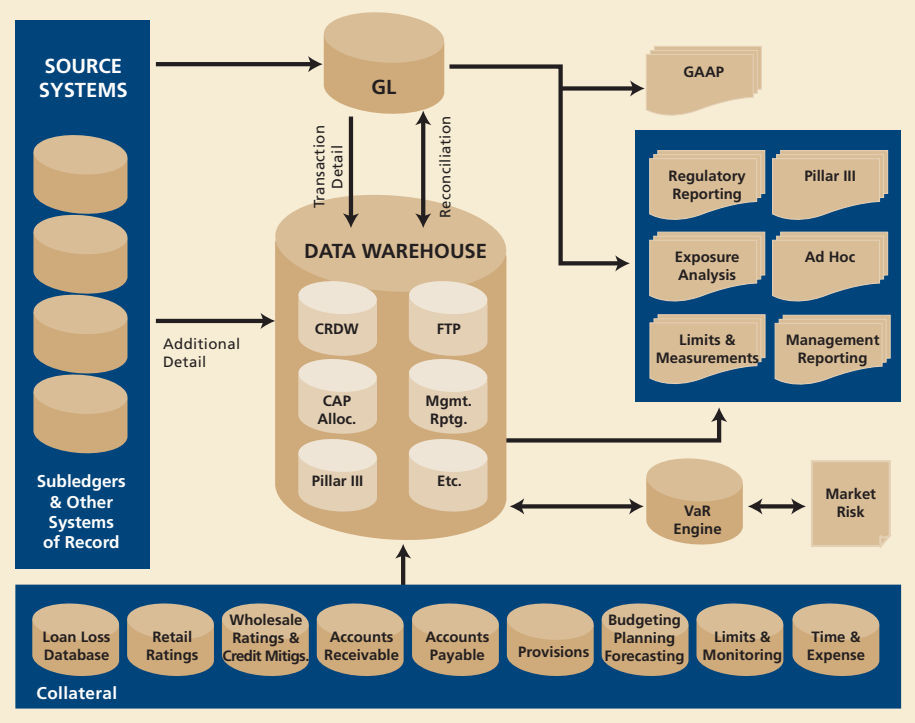
A: Eventually, there will be an opportunity to establish real patterns across the data that are required to respond to requests created in well-defined risk domains. This is already the case for credit risk, since some companies are creating a credit risk data warehouse (CRDW). This is distinct from the general ledger, which receives all transaction details.

Instead, the CRDW is fed credit data only. Very few companies have this type solution, which we describe as being at Plateau II (see Figure 4), but several organizations are building such systems. Of course, this approach can create a data synchronization problem since the same data is kept in different places.

***Q:** When and how can other risk-reporting functions, such as capital allocation, be handled through one data warehouse construct or using enterprise resource planning (ERP) solutions?*

A: Although very few companies are known to have gone this far to date in integrating the data infrastructure, it's reasonable to believe that vendors and system integrators will push for such a convergence. This will occur only if Plateau II has shown that it brings real advantages. Considering the current state of the art and the enormous issues related to dealing with imperfect data, legacy systems and governance issues, we don't expect this to happen for another 24 to 36 months at best.

Figure 5: Evolution of the Risk Management Architecture, Plateau III



The associated evolutionary plateau (see Figure 5) is, therefore, only one of the possible target states currently envisioned by financial organizations, despite the fact that it addresses the data synchronization and integrity issues mentioned in the previous question.

***Q:** What about compliance? With risk and financial systems not converging in the short term or even medium term, how can we define an end-state architecture that also covers compliance?*

A: We believe that planning and deploying what we define as a compliance architecture (see Figure 6) can be achieved in the absence of an all-encompassing, integrated risk and financial system solution. The specifics of this approach and components of the architecture are described (i.e., the alert bus, the rule and correlation engine and the case tool) in the following section.

Importantly, note that what we defined earlier as the key elements of this end state in the evolutionary path can be reached effectively from Plateaus II or III (see Figure 7). The critical implementation path is the deployment of the various risk and compliance management systems that then serve as feeder systems to the rest of the architecture.

DEFINING AN END-STATE COMPLIANCE ARCHITECTURE

Given the previous answers, the questions before technologists become: What does a plausible end state look like? What are the elements of compliance architecture?

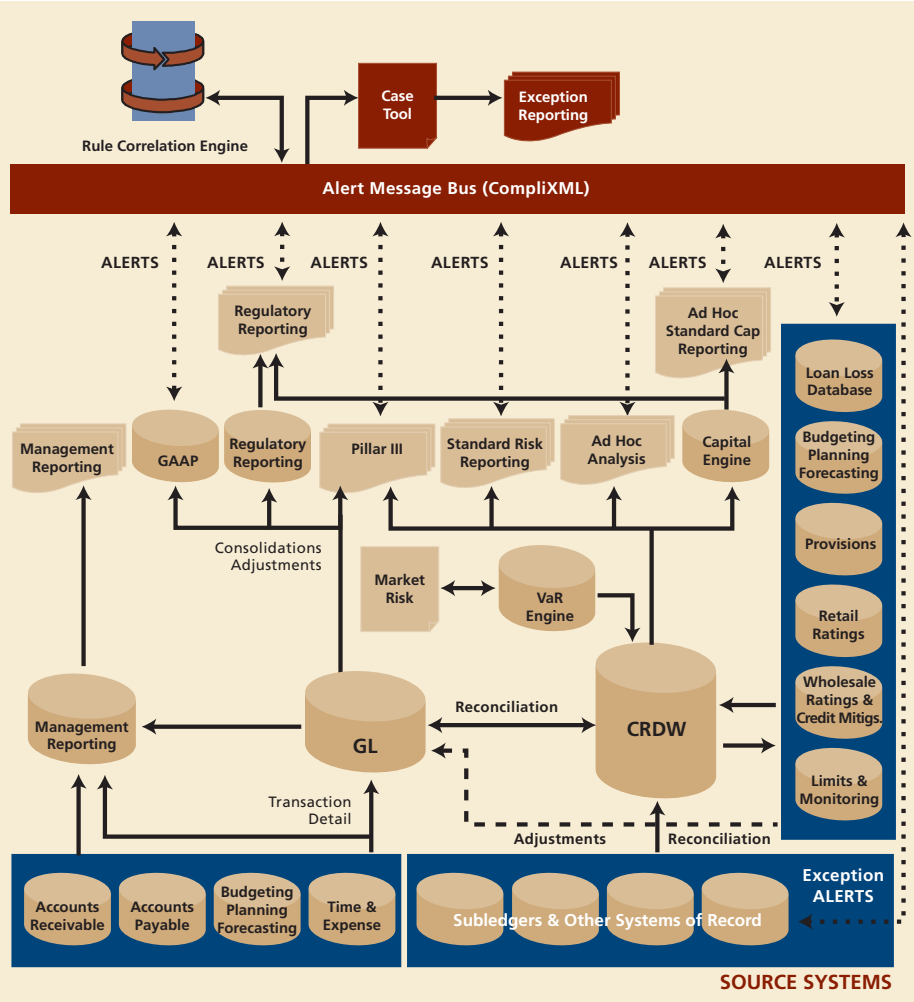
As noted before, most financial services organizations have focused until now on Sarbanes-Oxley assurance activities—that is, documenting their processes. However, few have implemented solutions that support, for example, process flow to make their processes automatic.

As a result, most organizations are at a stage in which they can represent to the regulators, by showing them their Visio™ diagrams, that when their employees accomplish certain tasks, they always use the same process. So, technically, they are in compliance. But what they are not in a position to do, if audited, is to demonstrate that each of the steps that comprise individual tasks is regularly and effectively recorded and time-stamped.

Let's look first at the infrastructure component of risk and compliance value chain digitization. All together the following elements should be used as building blocks of the enterprisewide compliance infrastructure architecture presented in Figures 6 and 7:

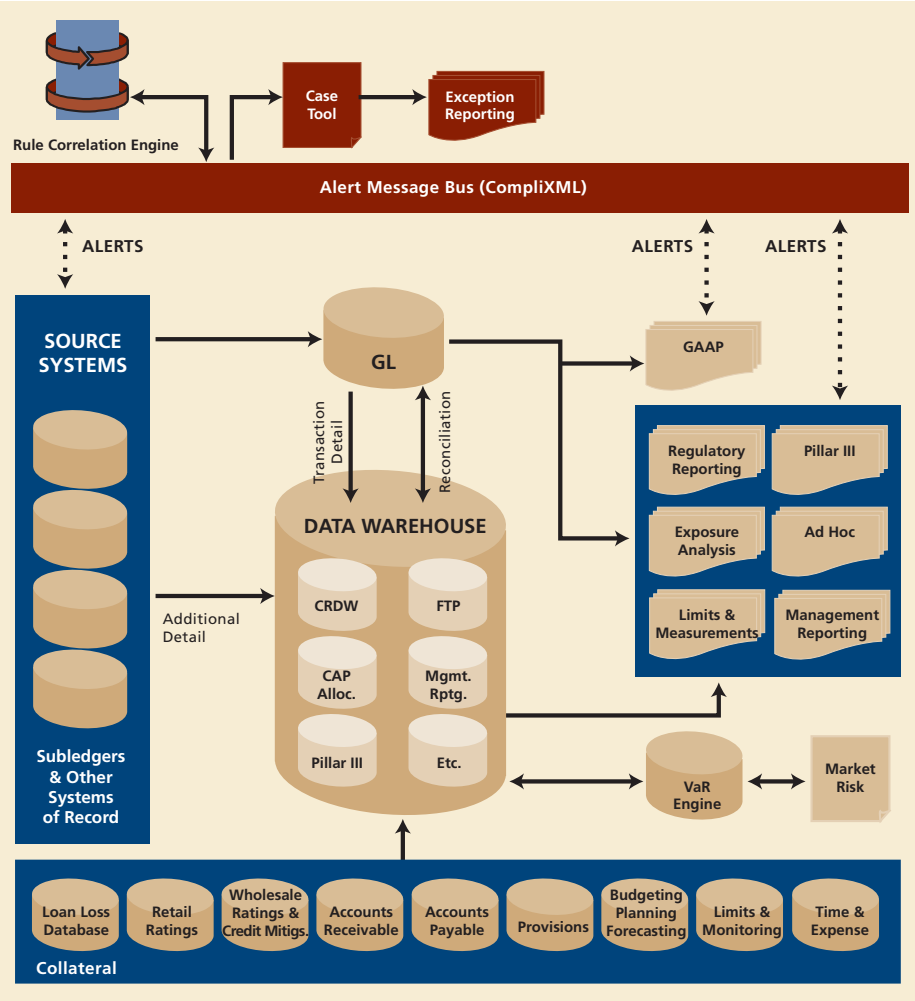
- **Development of, and adherence to, a common enterprisewide definition of what constitutes a compliance event (CE).** Defining a CE model can greatly benefit from using object-oriented techniques from a design standpoint. From an implementation standpoint, it can benefit from an XML-based description language, using an extensible schema to characterize CEs.
- **Development of interfaces generating well-formed CE messages from risk and compliance management systems.** This will be easier said than done. Essentially, most of these systems are integrated software and hardware solutions that combine high-volume storage capabilities with real-time data analysis to conduct correlation and pattern analysis. Although these platforms tend to be "vendor agnostic" in terms of getting data from heterogeneous sources and general ledger systems, they tend to use proprietary technology that does not necessarily lend itself to easy integration, except (hopefully) with systems from the same vendor.

Figure 6: Plateau IV—Adding Elements of a Compliance Architecture After Plateau II



- **Aggregation of CEs across risk and compliance management systems.** Envision the active networking of these systems across what could be referred to as a compliance bus, whose purpose is twofold:
  - Transforming risk and compliance systems into bidirectional systems so that an alert generated, for example, by the system managing access control could be taken into account by the system managing AML compliance.
  - All risk and compliance systems feed a comprehensive case management tool, defined below, that would enable financial services organizations to treat the combination of CEs in a consistent, traceable way.
- **Management of correlated CEs through a case management tool.** A case management tool can accelerate the centralization of processing of fraud or compliance issues throughout the organization. Using a rules engine and a workflow approach to facilitate the coordination of effort by compliance and risk management personnel

Figure 7: Plateau IVa—Adding Elements of a Compliance Architecture After Plateau III



can also be used to automate the generation of management reports and facilitate a Sarbanes-Oxley audit and investigative requirements.

Few of these components exist "as is" today, although some vendors and organizations have reasonable claims of having developed approximate substitutes for each element of this proposed conceptual architecture. For example, there are compliance-oriented case management tools available in the marketplace today, and many vendors are positioning their products in that direction.

Once the essential support "piping" has been built, technologists can focus on implementing the processes and business and technology services needed to implement the rest of the compliance framework, well integrated within the risk and compliance continuum. We address these issues further in the next article—"How to Create a Holistic Risk and Compliance Framework Part II: Integrating Systems, Processes and Tools."

ADDITIONAL CHALLENGES

It is appropriate to mention that some simplifications have been made:

- The upper layers of our model (i.e., the alert bus, the rule and correlation engine, and the case tool) can be implemented in a number of ways, using a workflow infrastructure to route possible CEs using various levels of escalations (see the "Escalation Requires a Framework" section in Part II of this series).
- In our discussion, not all reporting flows were represented in the diagrams. In particular and for simplicity, we did not indicate the connections between the front-end systems and the rest of the architecture. In reality, a lot of the case management we refer to here would not be triggered on the back end. They could also be triggered on the front end, in particular by customer relationship management (CRM) systems, change in transactional data or on operational data, such as transaction details associated with the movement of funds to various accounts, trader account activity in advance of a large trade, and control and policy violations.

  This approach can help to support both "passive" and "active" monitorings.[6]
- To a large extent, these CRM issues are also related to customer information management and, specifically, customer identity management (CIM), which comprises business strategies and frameworks that serve as organizing principles for rationalizing disparate customer identity data stores

[6]See the definitions of these terms in the sidebar "Active Versus Passive Technology" in Part II of this series.

and the individual technologies and processes that manage them.[7]

Also, an issue common to all plateaus is the fact that these architectures lend themselves mostly to the handling of structured data. Yet structured data is really only no more than 40 percent of the total data in use in typical financial services organizations. We believe, however, that the techniques and approaches presented here can be extended to the management of nonstructured data, possibly using metadata indexing and imaging systems and the approaches pertaining to information life cycle management.

INCORPORATING ORGANIZATION SURVIVAL AND IT SECURITY PLANNING CONSIDERATIONS

In modeling the risk continuum described early in this article, we purposely included business continuity, enterprise survival planning and IT security as domains. Financial services organizations are among the largest, most complex data processing entities in the world. In fact, it has been argued that the biggest risks they incur are those created through IT security threats or catastrophic loss of their data processing capabilities, either because of IT security lapses or an inability to recover from or survive a catastrophic event.

First, a clarification on nomenclature is in order, as a number of disciplines have emerged to deal with the broad question: How can an enterprise *a priori* or *a posteriori* either prevent or remedy threats that undermine not only the integrity of its computing and communications infrastructure and systems but also its ability to function as a going concern after a catastrophic event?

Broadly speaking, IT security deals with prevention *a priori* of those risks in the IT realm with a focus on prevention (*a priori*) of these risks and significant attention, with specific subdomains having been well identified (see Figure 8 and also our articles on IT security[8] elsewhere in this issue).

In contrast, a number of disciplines deal with threats *a posteriori* [i.e., once they have had an effect (see Figure 9)]. These include:

- Historically, backup and recovery (B&R) procedures have formed the essential way to restore IT operations.
- Over time, several complementary disciplines have evolved with an ever-increasing scope of concern related to how to resume business after execution of a threat, including disaster recovery planning (DRP), which focuses exclusively on the recovery of technology infrastructure, and business recovery planning (BRP), which goes beyond technology issues to deal with issues such as how to deal with people and communications in such an event.

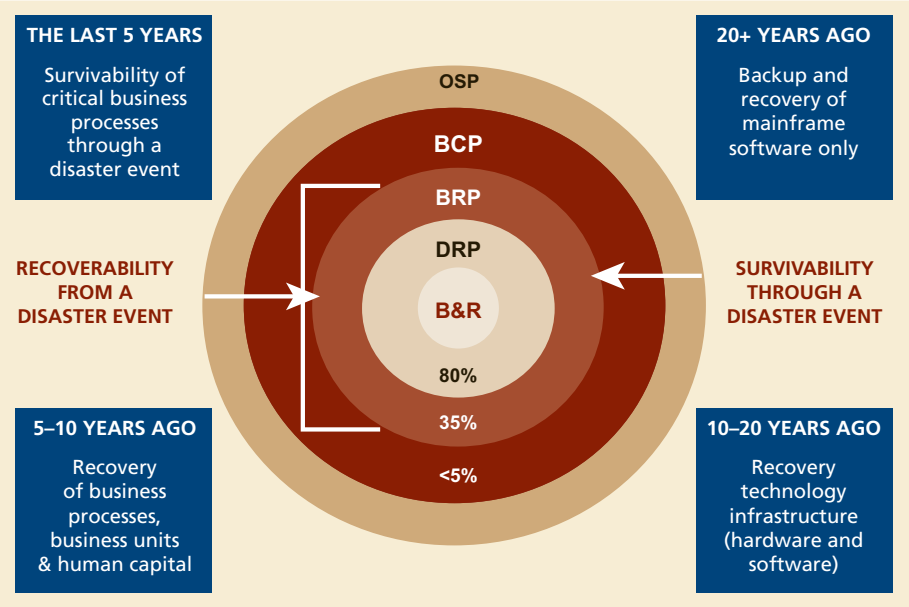
Figure 8: IT Security Domains and Subdomains

SECURITY DESIGN & IMPLEMENTATION SERVICES	SECURITY ASSESSMENT	IDENTITY MANAGEMENT	NETWORK & PLATFORM HANDLING	SECURITY OPERATIONS
• Security Program, Strategy, Prioritization, Budgeting and ROI • Security Architecture Development • Perimeter/Host Security and Standardization Processes • Identity and Access Management Solutions	• Policy and Procedure Analysis • Organizational/ Operational Discovery • Configuration Reviews • Penetration Testing • Application Security Assessment	• Access Control • Single Sign-On • Provisional Workflow • Lightweight Directory Access Protocol (LDAP) Directory Services • Authentication Systems	• Secure Perimeter • Platform Hardening • Application Security • Secure Remote Access • Intrusion Detection and Prevention	• Intrusion Detection • Incident Response • Risk Management • Compliance Management • Managed Security • Patch Management

[7]See "Risk and Identity Management for Financial Services" by A. Berson in this issue or "Customer Identity Management" available at *www.bearingpoint.com/custident.*

[8]In addition to the articles referenced in footnote 6, see "Infrastructure Implications of the Convergence of Risk and Compliance" by G. Rossi in this issue.

Figure 9: From Backup to Enterprise Survival Planning



- Beyond recovering from a disaster event, organizations are also concerned about surviving catastrophic events in a way that ensures a real level of continuity of operations. Business continuity planning (BCP) is built on top of all previous disciplines with an emphasis on technology.
- Finally, in addition to typical BCP components, Organizational Survival Planning (OSP) integrates plan testing, maintenance, enhancement, user training and awareness, crisis communication and management, and organizational psychology with the plan itself to create a comprehensive enterprise solution.[9]

Each domain deserves its own treatment in terms of how it relates to risk and compliance issues—in fact, such discussions are covered elsewhere in this issue of the *Journal*. But as a broad statement, convergence of the risk and compliance domains will encompass business continuity, OSP and IT security. Yet they are too often omitted from the discussion of risk on the grounds that some systems discussed in this article are essentially back-office systems.[10]

The typical argument is that back-office systems are relatively insulated from the Internet infrastructure, so they are less prone to external attacks. As such, they are usually excluded from the scope of most business continuity plans, and certainly from enterprise survival plans. These arguments are flawed and shortsighted for the following three reasons, among many others:

- The existence of a comprehensive business continuity or enterprise survival plan is explicitly recognized as a way to mitigate operational risk and thus is an element of Basel II. In addition, the need for a good business continuity or enterprise survival plan for compliance systems also now stems from the fact that regulators demand and expect very short response time when they issue requests for documentation.
- Conceptually, there are no reasons to distinguish damages incurred through fraud activity from those created by malignant attacks on an enterprise system. Both can be characterized as what compliance and risk managers label IUM threats—intentional, unavoidable and malicious[11]—which suggests a coordinated approach against that class of risks.
- Compliance systems usually require strong user identity and access control management frameworks, one of the key elements of the IT security domains.

The good news is that OSP and IT security are getting a lot of attention these days. The bad news is that they are seldom incorporated in a holistic view of enterprise risks. Financial services technologists can help remedy that situation by approaching these issues as part of their overall planning and modeling activities.

IN CONCLUSION

As this introductory article shows, a holistic approach to risk and compliance management is a necessary but somewhat daunting task because of the range of issues that need to be considered.

With many dependencies existing across the problem space, technologists are asked by senior management to be aware of a very wide scope of issues and are expected, perhaps unrealistically, to

[9] OSP is developed by proactively addressing survivability of an organization's mission-critical business processes through a significant business event.

[10] This is not, in fact, the rule; see the second bullet point in the "Additional Challenges" section on page 12.

[11] As opposed to APB—avoidable, predictable and benign—as discussed on page 17 in Part II of this series.

maintain a working knowledge of a very wide range of techniques and technologies to address these issues. To help with this dilemma, we offer our "top 10" list of compliance "to-dos" for technologists:

- **Start from the top.** Work with industry and internal compliance and risk management groups to stay aware of how their thinking is evolving with respect to priorities and how regulations and corporate policies themselves are evolving toward a holistic approach to risk and compliance.
- **Help others in risk and compliance to help you.** In particular, help corporate compliance and risk management groups document critical compliance and risk management processes, as well as related cross-process dependencies and patterns.
- **Share your know-how and techniques within the enterprise.** With respect to the first two points above, help your compliance and risk management colleagues and yourself by introducing the concept of use case and pattern analysis techniques to develop and organize findings. Similarly, technologists proficient in using unified modeling language (UML) and other techniques, such as modeling objects through extensible business reporting language (XBRL), as descriptive languages for articulating findings can promote the use of these tools and constructs outside of the IT function.
- **Promote the emergence of standards.** On the basis of all of the above, work with compliance and risk management groups to initiate and/or support industrywide initiatives to define common standards for what constitutes CE objects. (Do not use CEO as an acronym, though.[12])
- **Work iteratively across technology threads.** Create a working community of interest, a task force, within the IT organization and across your enterprise with representation from all domains mentioned in this article, from the financial systems manager to IT security. Some of the issues that will slow down the convergence of activity are related to governance and organization of the IT function. For example, the risk, finance and compliance functions are usually supported by different technology teams.
- **Articulate your plan.** Ask this task force to articulate your own path toward convergence with a special emphasis on your strategy for where and how data is going to be shared. This should be expressed not only in the form of an end-state conceptual architecture but also a high-level description of what the implementation plateaus will be going forward, with specific emphasis on what is going to happen within the next budgetary cycle—by definition the first implementation plateau.
- **Clarify governance issues.** Demand that a clear governance model be used to determine how investment budgets and business cases are developed. In many cases, technologists should not have to develop business cases for investment. Although they should be responsible for producing budgetary data to model implementation costs of risk and compliance projects, they are too often put in a position of developing the whole business case, something they are ill-equipped to do and that should be performed under the aegis of the risk management or compliance corporate officer.
- **Clarify the role of IT.** Demand that the role of the IT group be clarified in terms of when it should act as enforcer or advisor to the business. This issue is often overlooked and contributes to ambiguity about how risk and compliance activities are funded.
- **Experiment.** Start proof-of-concept projects to explore interoperability of point solutions and to test how a compliance architecture, as defined in this article, could be implemented within the organization.
- **Share findings across the industry.** This last point is key. It is doubtful that any one company will be able to develop best practices in isolation, so the more industry debate there is as to how to identify patterns, such as fraud patterns, the more likely everyone is likely to benefit.

From a practical standpoint, the technology community will have to continue to implement point solutions in the domains where requirements are clear enough and the technology mature enough to allow it. But in selecting point solution platforms, be sure to consider how open the architecture is to allow for further cross-point solution integration.

The same kind of caution applies to selecting the right model for data management. We suspect that most organizations will continue to experiment with focused data marts despite huge pressure from vendors to convert to the deployment of enterprise data warehouses. It is doubtful that any one firm can derive a real competitive advantage from implementation of compliance risk management tools. So this is a call for action across the industry to cooperate and share best practices.

We encourage organizations to share how they model CEs, how they implement their overall compliance architecture, and how they integrate their architecture with the rest of their risk and financial management tools.■

[12] C-level executives do not want to be objectified, much less be associated with the notion of exception when it comes to compliance.

How to Create a Holistic Risk and Compliance Framework

Part II: Integrating Systems, Processes and Tools

Abstract

Financial services organizations are undertaking an array of compliance initiatives in response to discrete regulatory mandates such as the Sarbanes-Oxley Act and Basel II. Institutions can improve compliance enterprisewide by bringing these efforts into a holistic compliance framework. Such a framework facilitates taking the right actions at the right time in response to, or in anticipation of, compliance-related events. Rather than requiring new systems and technology, the holistic compliance framework leverages the existing, sizable investment institutions have made in compliance systems and technology. This article builds on the previous article in this issue, "How to Create a Holistic Risk and Compliance Frame-work Part I: Building the Data and Workflow Infrastructure," by discussing how to link key applications into a workflow framework on top of the technology risk and compliance infrastructure proposed in the introductory article.

Connecting the Compliance Buoys

Compliance is like a cork in the water for financial institutions. It bobs about and occasionally dips below the surface amid day-to-day business concerns. But it always pops back up, at times with ferocious force.

Today, of course, in the era of Sarbanes-Oxley, Basel II and other edicts, compliance is never far from the view of executives. They now carry personal responsibility for it. They have spent millions of dollars on technology and systems to attain it. And they recognize that, despite their best efforts to run the business efficiently, ethically and legally, compliance will rear its head in diverse and surprising ways, from simple mistakes to gross malfeasance.

Given the high stakes now associated with compliance, institutions need a network of buoys in the regulatory waters. Compliance processes and systems need to be interconnected—among themselves and with the rest of the risk-compliance continuum process and system—in a holistic framework that allows rapid, appropriate responses when potentially compliance-related events occur, or even before they happen.

The good news is that the sizable technology and systems investments that institutions have made to meet various mandates can in fact be leveraged beyond the silos of Sarbanes and Basel. A converged, coherent view of the institution's exposures and compliance mechanisms, one that facilitates taking the right action at the right time, is possible.

But first, technologists, and probably anyone else, should understand the difference between compliance management and audit, the five types of compliance issues to be considered, and the two types of events that trigger non-compliance.

Audit Is Dead, Sort Of

Businesses have long relied on regularly scheduled audits based on standard rules as a methodical process to ferret out errors, irregularities and controls needs. Today, however, financial institutions cannot depend on the rules-based cycle audit to address the armada of regulatory and compliance issues they face.

New requirements for operational risk reporting and for personal attestation of processes and controls are proving beyond the capability of the cycle audit to effectively protect management, employees, customers and shareholders. Further, even with thousands of material controls in place, the audit cycle does not reveal what happens when processes change without triggering alerts. It is in these process deltas that much of the enterprise risk occurs.

Certainly, the cycle audit will not go away. But active case and policy management structures, which trigger alerts and launch audits for cause, will assume a greater and greater role as institutions ply the compliance waters. These structures will enable the fundamental shift from a rules-based to a risk-based approach.

COMPLIANCE IS NOT A SWAMP

Some financial institutions fear that developing the systems and extracting the data to meet compliance requirements means wading into a morass of confused systems, processes and people. But compliance is not a swamp. Instead, it is a bounded problem driven by a tight set of rules, statutes and regulations, which many financial institutions can respond to with initiatives in five key areas:

- Employee management
- Disclosure and conflict management
- Sales and competency management
- Surveillance
- New product and new customer development

Whether an institution chooses to apply minimal resources to compliance or plans to use compliance as a differentiator, these five factors guide the most critical aspect of the process—the activities of employees.

Effective compliance requires that employees be competent, nonconflicted, trained, well managed and aware of the importance of legal and ethical behavior as they develop products and interact with customers. A culture of compliance needs to be in place before prevention of problems can be realized.

A framework that provides proper controls—from bringing employees on board to guiding what, when and to whom they sell—will help protect the interests of the institution, its staff, its customers and its shareholders. It also will allow product development and customer initiatives to proceed informed by regulatory and compliance mandates.

Much of the compliance effort will focus on connecting these five domains to provide a cross-silo, converged view of compliance activities and exposures. Achieving this view will require the development of workflow, document management, data integration and business process management (BPM) capabilities. This is where technologists can make the greatest difference: they can digitize the compliance value chain.

Compliance is not a swamp… Instead, it is a bounded problem driven by a tight set of rules, statutes and regulations.

DIFFERENT EVENTS NEED DIFFERENT APPROACHES

Sometimes bad things happen unintentionally. Other times, people are willfully bad. Both types of events must be addressed in the compliance world.

In the first category are APB events or compliance events (CEs). These are *avoidable*, *predictable* and *benign* occurrences that can result from an employee misinterpreting an instruction or checking the wrong box on a form. They are avoidable because proper controls can keep them from happening. They are predictable because people are human and make mistakes. And they are benign because no one stood to gain from what occurred.

APB events can be controlled. Using structured data supported by structured processes and applications, systems can be deployed to make sure the wrong box isn't checked.

Quite different are IUM events—*intentional*, *unavoidable* and *malicious* occurrences. In these cases, someone seeks to use material, nonpublic information or exploit a system or process loophole for personal gain or to avoid regulatory accountability. IUM events are unstructured. Who is out there? What are they trying to do?

The processes and systems in place to handle APB CEs are of little use in answering these questions. Instead, resolving IUM issues requires a separate set of applications and processes, which support unstructured data and rely heavily on the expertise of the compliance team.

Despite their polar nature, APB and IUM platforms must coexist in the institution's compliance environment. A vital tool for reducing the occurrence of such events is a converged framework for detecting IUM and APB events and for feeding a synthetic dashboard and case tool that provides central monitoring and management of both types of compliance exceptions.

ESCALATION REQUIRES A FRAMEWORK

As noted elsewhere in this issue,[1] both APB and IUM types of CE must be examined to determine whether or not it is adjudicative.

Typically, two tiers of business logic filters are applied to this process. The first tier identifies whether an occurrence is an infraction. If so, it then is routed to the next level of analysis. On this second tier, a compliance professional employs a set of policies and procedures to determine whether the event is potentially adjudicative and should be escalated to higher-up decision makers.

[1]See the "Additional Challenges" section of Part I of this series.

In most compliance organizations today, infractions are routed to the person with the fewest cases in queue. Such an approach does not take advantage of each person's special expertise and background, nor does it provide a view of individual workloads that takes into account case complexity.

Routing infractions to the right people based on specialization and a structured framework can result in better use of a costly, thinly spread workforce, increasing the compliance department's ability to examine and adjudicate events. In addition, such an approach can help create an analytic platform for examining behavior and activity patterns across organizational, jurisdictional and product silos, where compliance problems often arise.

KEY COMPONENTS OF A HOLISTIC FRAMEWORK

Most institutions have made significant investments in compliance. In some cases, the costs for systems and technology, legal fees, and internal staffing have reached hundreds of millions of dollars.

Amid this effort and expense, a truth has emerged: There is no silver-bullet solution to the compliance problem. Rather than replace existing compliance systems, a converged, holistic compliance framework connects existing systems using document management, BPM, business rules engines and business activity monitoring (BAM) systems. BAM systems play an important role in the compliance framework by providing executives with insight into regulatory requirements and the institution's ongoing compliance activities.

Fortunately for a number of institutions, many of the technologies required to create a holistic compliance framework already are in place. The task lies in connecting these systems and processes through workflow, document management, data management, BPM and integration (see Figures 1 and 2).

Figure 1: The Holistic Compliance Framework: People and Systems

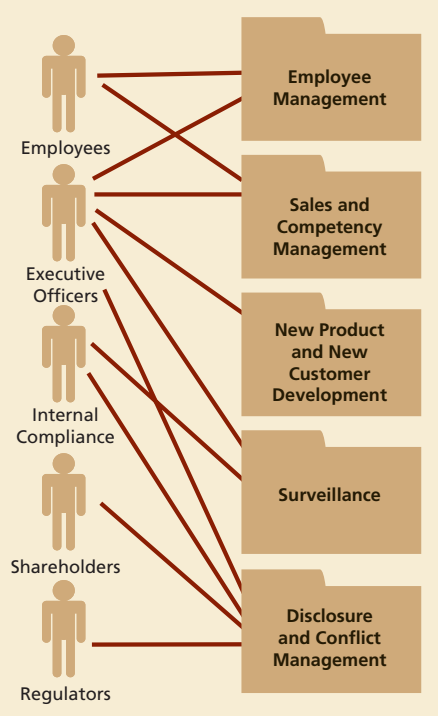


Figure 2: The Holistic Compliance Framework: Systems and Tools

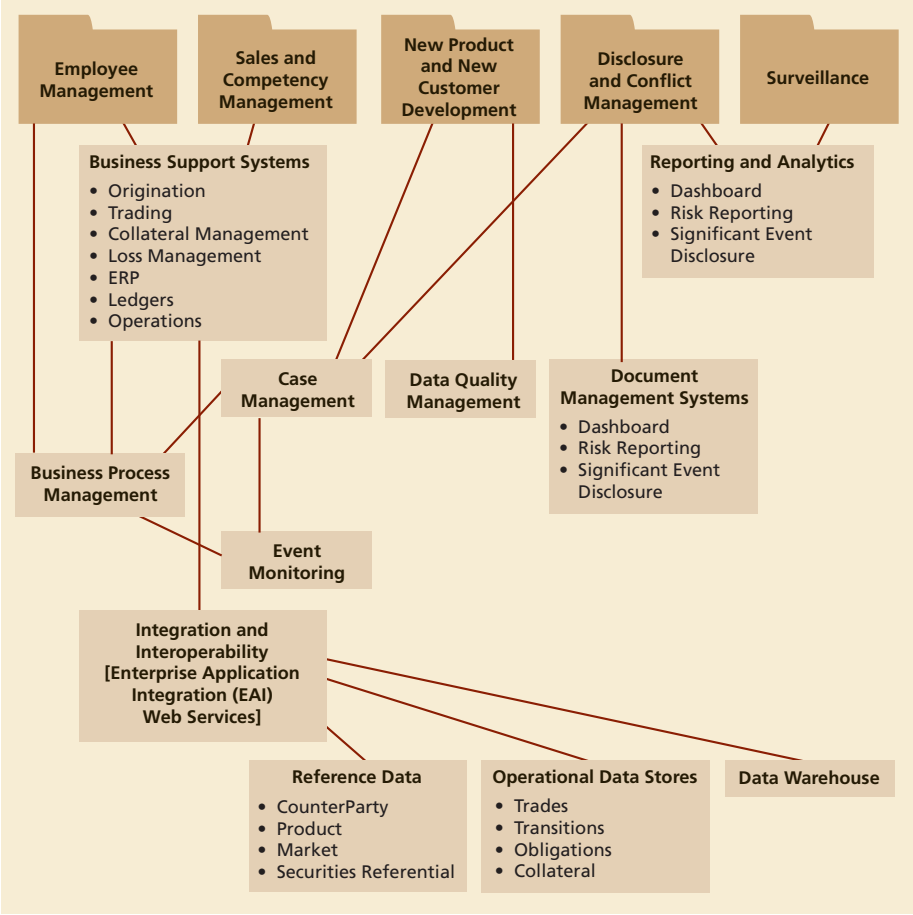


Figure 1 illustrates, at a high level, the relationships between people and systems in the five key compliance activity areas—employee management, sales and competency management, new product and new customer development, surveillance, and disclosure and conflict management.

A well-connected set of business and technology services are needed to support these people and technology interactions.

At a high level, everyday business support, reporting and analytical tools support the five key compliance activity areas (see Figure 2). These end-user systems are supplemented by and connected to case management, data quality and document management tools.

Establishing these connections can be achieved by leveraging digitization tools and the type of risk and compliance framework infrastructure discussed in Part I of this series.

Lastly, a major focus area for many organizations will be getting a handle on the underlying operational, reference and archived data.

DIGITIZING THE COMPLIANCE VALUE CHAIN: TOOLS AND IMPLEMENTATION CONSIDERATIONS

Once an infrastructure is in place and services and systems that need to be integrated have been identified, technologists face typical challenges and implementation considerations found in any digitization projects:

- **Connecting to business support applications.** Systems must be modified in order to link information and enforce policies, or must be linked into a workflow framework that audits and controls cross-application procedures and exposes audit events. These capabilities are necessary for compliance with the Basel II Accord Pillars I & II, Sarbanes-Oxley Section 404, the Committee of Sponsoring Organizations (COSO) and Control Objectives for Information and Related Technology (COBIT) controls. Functionality should be created to provide previously nonexistent linkages, such as losses to event and collateral to transactions, for Basel II Pillar I. Ledgers and subledgers need to support these linkages, categorize the financial effects accordingly and map to new requirements.
- **Implementing document and/or information life cycle management tools.** On the surface, regulators are looking for transparency. Do you have an understanding of how you get your numbers? Can you provide documentation? How does it all work? How is it enforced?

  This information is essential and must be easily accessible to and understood by various management levels to meet Basel II Pillar III and Sarbanes-Oxley Section 404 requirements. Documentation verifying a company's understanding of customers and due diligence must be readily acceptable for anti-money laundering (AML) purposes. Meeting these needs involves clear documentation of technology assets, architectures and source applications.
- **Implement BPM to tie everything together.** BPM offers a "low-hanging fruit" way to relieve regulatory pressures on controls, even across legacy applications. It is key to setting policies and building regulator confidence in linkages required for Basel II Pillar II and Sarbanes-Oxley Section 404. BPM provides a mechanism to supplement linkage data currently not required or being captured. BPM also provides a mechanism to escalate issues in a traceable manner.

The specific challenges associated with the digitization of the compliance value chain include:

- **Enabling reporting and analytics capabilities.** Basel II Pillar III and Sarbanes-Oxley Sections 404 and 409 are fundamentally about reporting and public disclosure. Section 404 and AML edicts mandate event reporting. Pillar III requires the ability to categorize exposures. Also needed are scorecards of controls effectiveness and enterprise governance management tools such as roll-ups.
- **Event monitoring and case management.** Passive monitoring and control of policy-break events such as money laundering, customer setup and risk ratings is vital to meeting AML, Sarbanes-Oxley and Basel II Pillar II requirements. Clear documentation of breaks and follow-ups also is required.
- **Integration and interoperability.** These capabilities help fulfill Sarbanes-Oxley Section 409 requirements for real-time disclosure and are key to management visibility. Integration and interoperability help improve enforcement through less manual, human interaction.
- **Data quality, reference data, operational data stores (ODS) and data warehousing.** These resources help establish linkages between customers and exposures that are essential to Basel II Pillar I compliance and contribute to confidence in the integrity of data produced for Pillar III. The use of these resources to link, aggregate and provide information can be applied to multiple data convergence approaches. These issues have been examined in great detail in Part I of this series.

THE ROUTE TO A HOLISTIC FRAMEWORK

While the tenets and core services to be implemented in a holistic compliance framework are the same for most organizations, the physical architecture and the implementation journey will

vary. Typically, the initiative will involve transformation of an existing compliance technology environment, requiring a combination of sound strategy and execution tactics. We suggest the following approach to creating a framework for managing and controlling the breadth of compliance issues:

- **Clarify your priorities.** It is important to understand the "burning platform" that is driving change of the compliance framework. Identify the key issues: Regulatory response efficiency? Improved controls? Accelerating case resolution? These priorities will continually remind the organization of the importance of the change initiative and will help establish the road map for compliance framework transformation.
- **Identify the guiding coalition.** As with any change initiative, strong, respected leadership is required. The leadership team will help deal with uncertainty during the journey by arbitrating priorities, making architecture decisions and championing funding. Who makes up the leadership team? Do their actions reflect their words?

Technologists who want to implement a holistic architecture that supports the full range of risk and compliance management issues are confronted with challenges that seem familiar if you have attempted the same kind of integrated approach in other domains.

For example, take the field of information technology service management (ITSM). ITSM requires the integration of systems aimed at performing a range of services, such as fault management or change management, a challenge equivalent to integrating the risk and compliance management systems in the model presented here. Usually, ITSM systems need to be tied in through a "manager of managers" to provide an end-to-end view of the enterprise IT infrastructure. Yet anyone who has tried to link up a trouble-ticketing platform to an asset

ACTIVE VERSUS PASSIVE TECHNOLOGY

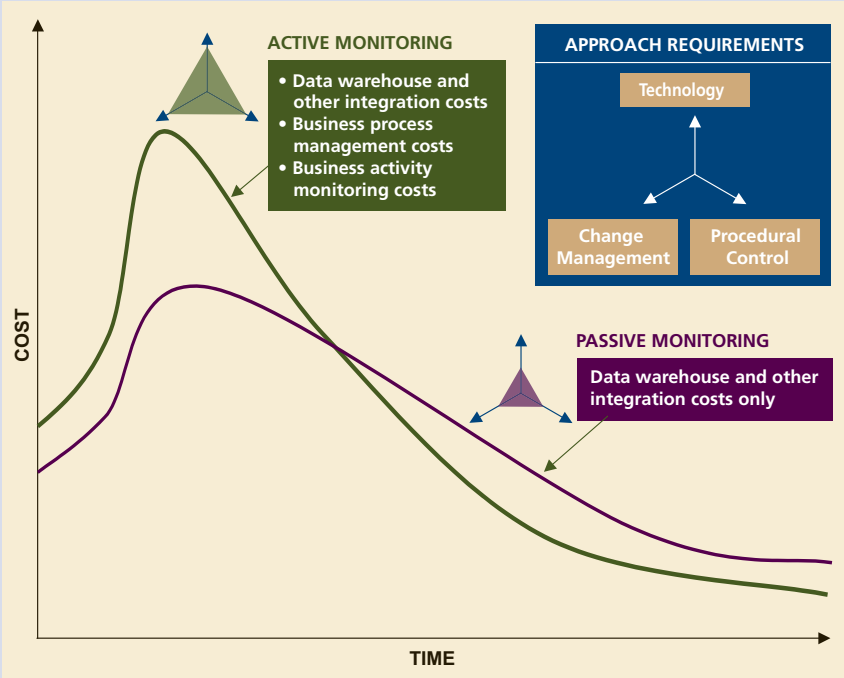
Active compliance technology uses technology to *enforce* workflows, procedures and policies. **Passive** compliance technology is *aware* of what is happening and *notifies* people appropriately.

Passive technology is nonobtrusive and requires less effort to implement. These technologies monitor activity and alert parties of compliance violations after the violation has taken place but allow for the case management of those events.

In order to complete a task, active technology forces members of the organization to follow a specific process as required by the system. For example, an active technology enforcement of a credit risk policy from Basel II will force the user to execute the credit and exposure checks with the policy-specified risk models before originating the loan.

Active enforcement has a higher upfront cost but requires fewer people to enforce and can reduce overall risk (see Figure 3). **Passive enforcement** requires a small initial investment but requires ongoing incremental labor effort to enforce policy.

Figure 3: Cost/Labor Comparison Between Active and Passive Monitoring



management system can testify to the difficulty of the task at hand, not only because of the same issues of standards and interoperability mentioned in our discussion of the compliance architecture model, but also because of issues of change management, governance and process re-engineering that inevitably arise in these situations.

Technologists can make the greatest difference: they can digitize the compliance value chain.

Consider also that, in the ITSM field, the Information Technology Infrastructure Library (ITIL)[2] provides detailed prescriptions as to how to define and integrate the range of relevant processes. No such library exists for risk and compliance processes. As a result, IT practitioners will have to deal with near-term immediacy with an eye to how the situation will pan out as a whole in the long term.

So how to proceed? First, recognize and leverage the fact that there is a silver lining to the current picture. The convergence of risk and compliance management is in its early stages, but its direction is well established. Regulations, such as Basel II and Sarbanes-Oxley, are creating a mandate to invest in technology infrastructure. Done right, this infrastructure will enable the IT community to build the foundation of enterprisewide risk and compliance systems.

The trick will be *not* to build the next generation of *siloed* solutions. This can be accomplished by balancing the need to implement point solutions with the need to deploy those solutions within a flexible, adaptive architectural framework. Such a framework will enable the eventual connectivity between these point solutions within the compliance framework described in the previous sections.

Thus the optimal path toward convergence over the next few years should be:

- **Near term**—Significant opportunities exist now in the converged finance and risk spaces given the spending associated with regulatory pressure from Basel II and Sarbanes-Oxley, as well as the management mandate that chief financial officers deal with these issues through the deployment of dedicated data marts in support of these efforts. With respect to compliance, we also see immediate implementation of stand-alone point solutions, particularly case management tools.
- **Long term**—Compliance frameworks and architectures will likely evolve similar to those already being implemented for finance and risk management. They should reach a level of maturity in roughly three to five years. These frameworks and architectures will leverage process management, case management and content management overlays to the existing, converged finance and risk management data architectures. These can lead to the deployment of architectures that are conceptually equivalent to the compliance architecture described in this article. A converged finance, risk management and compliance model will emerge, leveraging process and data practices and assets.

In the meantime, continuous planning is urgent. IT practitioners are and will continue to be led into projects that deal with short-term challenges. They incur the risk of finding themselves, in the future, with multiple disparate solutions that instantly achieve legacy status. Point solutions for compliance may be implemented now—much as they have been for finance and risk management—with a focus on the architectural components that will likely exist in the converged finance, risk management and compliance end state.

This said, even partial implementation of the proposed model can address the issue of how various compliance enclaves can benefit from integrated case management capabilities.

Specifically, we see opportunity for content management and BPM implementations, initially to solve point compliance challenges, such as document retention and Sarbanes-Oxley transparency, but evolving to a more enterprisewide role.

Simultaneously, we expect industry and regulatory bodies to identify patterns and share best practices that will help determine how to define the rest of the compliance architecture components, particularly the definition—most likely XML-based—of what constitutes CE objects and the rules that will enable risk and compliance managers to cross-correlate their findings in real time.■

[2]See, for example, *www.ogc.gov.uk/index.asp?id=2261* for an introduction to the IT Infrastructure Library.

Risk and Identity Management for Financial Services

Abstract

The global connectivity provided by the Internet has allowed organizations to network easily with their customers, suppliers and business partners. However, by moving the boundaries of an enterprise away from the corporate headquarters, the Internet has created a new set of security challenges. These include threats that either did not exist before or have become much more serious and complex because of the ease of access and "virtual close proximity," not only for welcome participants, such as customers, partners and suppliers, but for unwelcome intruders and hackers. Customer identity management (CIM) works in concert with customer relationship management (CRM), information security and risk management to satisfy customer expectations while protecting the interests of the enterprise. The CIM framework provides a new functional capability that helps companies adopt a customer-centric business model, with the potential to drastically improve customer experience. This new functionality is known as a federated customer identity store, or customer hub. This article provides a general introduction to the drivers of CIM and key constructs associated with CIM. It also presents a reference architecture based on service-oriented architecture (SOA) principles that technologists can use to help implement identity management as a core component of the risk-compliance continuum.

THE IDENTITY MANAGEMENT IMPERATIVE

The global connectivity provided by the Internet has allowed organizations to build networks that help improve profitability and competitiveness by connecting their customers, suppliers and business partners. Companies have developed business strategies focused on increasing the volume and variety of transactions and business activities conducted in online environments. In addition, these strategies focused on building networked communities of interest that support strategic partnerships and various outsourcing options.

However, by moving the boundaries of an enterprise away from the corporate headquarters, the Internet has created a new set of security challenges. These include threats that either did not exist before or have become much more serious and complex because of the ease of access and "virtual close proximity," not only for welcome participants such as customers, partners and suppliers but for unwelcome intruders and hackers.

A consequence of the Internet's proliferation is a strong appreciation of the value of information assets and the ever more urgent need to protect them given the ease with which they can now be compromised. Thus, information security, often misunderstood and frequently underprioritized and underbudgeted, has a new mandate for rapid transformation. Organizations see the need to heighten information security from a traditional set of technologies focused on the *exclusion* of all but a few known users at the enterprise perimeter, to a new paradigm of *inclusion* that allows and, in fact, invites all customers, prospects and partners to participate in the enterprise business.

This new inclusion model is centered on the knowledge of and ability to verify the identities and entitlements of users. Properly executed, it can help improve customer and enterprise experience by reducing the number of "checkpoints" that users must pass through to conduct business. Because this new paradigm drastically increases the population of users, prospects and partners allowed to "touch" the enterprise, application of it must address issues of privacy, confidentiality, integrity and availability of information—attributes that have become key business, risk management, regulatory and compliance requirements.

The paradigm of inclusion has given birth to a new set of information security disciplines collectively known as *identity management*. Identity management is a business and technology strategy and comprehensive architecture framework focused on creation, management and use of common and persistent identity credentials and entitlements. These credentials and entitlements govern decisions related to authorizing the use and availability of information and systems and supporting privacy and security.

WHAT IS IDENTITY MANAGEMENT?

Identity management comprises business strategies and frameworks that serve as organizing principles for rationalizing disparate customer identity data stores and the individual technologies and processes that manage them.

Identity management defines how to manage the flow, consumption, security, integrity and privacy of customer data across the enterprise in line with business demands.

Identity management helps organizations better understand their relationships with customers across line-of-business and partnership boundaries.

We have identified key issues surrounding the convergence of identity management with customer relationship management (CRM) and risk management. This convergence has given rise to *customer identity management* (CIM), a new model for helping organizations gain information about their customers while keeping that information private and secure.

EXPLORING IDENTITY MANAGEMENT

The driving forces behind identity management include the need to:

- Enhance security, including authentication of users, authorization and access control enforcement, and protection of information assets.
- Improve the customer experience of navigating online enterprise services by providing seamless, transparent access to all authorized resources based on a single act of authentication, known as a single sign-on.
- Improve information technology efficiency. Identity management technologies help reduce user-management administration and support costs by providing automated facilities for credential creation and synchronization, such as operator-less password synchronization, reset and recovery.
- Improve user efficiency. The identity management component known as user provisioning can support automated workflow-based self-provisioning of users, reducing user downtime from provisioning delays.
- Reduce audit and regulatory compliance exposure to regulations such as the Gramm-Leach-Bliley Act, the Sarbanes-Oxley Act and the USA PATRIOT Act. This is accomplished by enabling and enforcing security controls including, but not limited to:
  - Centralized profile and privilege management.
  - Enforcement of unique user identifications.
  - Role- and rule-based access controls.
  - Elimination of orphan accounts (accounts that have no owners in systems of record).
  - Verifiable and timely reporting.
  - Auditable access to resources and applications. Identity management solutions support creation and maintenance of secure, verifiable and auditable logs of access and authorization events.
  - Password policy enforcement.

IDENTITY MANAGEMENT AND COMPLIANCE

The dramatic increase in cyber crime, the frequent lack of internal corporate financial controls and the recognized value of information to companies and individuals have resulted in the enactment of legislation and regulations requiring significant improvements in information protection. In the United States, for example, the Health Insurance Portability and Accessibility Act (HIPAA) mandates stringent protection of all individually identifiable healthcare information. Information protection requirements have been placed on government and private organizations by legislation such as the Homeland Security Information Sharing Act (HSISA, H.R. 4598). These new regulations contain mandatory compliance requirements that deal with data privacy, confidentiality, integrity and availability.

The list of new requirements focusing on information protection continues to grow. A compendium of rules and regulations with identity management implications can be found in the sidebar, "Identity Management and Data Security: The Legal Landscape," on page 28.

IDENTITY MANAGEMENT AND IDENTITY THEFT

To effectively protect information assets in the Internet-connected world, an enterprise must be able to manage user identities. Identity management helps organizations know who has access to information and systems, who has granted that access and for what reason, and how to assuredly revoke access privileges from certain users at a moment's notice.

One clear application of identity management is protection against identity theft—the fastest growing white-collar crime in the United States. The 2003 Federal Trade Commission report on consumer-related crimes stated that more than 27 million people had been victims of identity theft in the previous five years. The total cost of identity theft to individuals in 2002 was reported at US$5 billion, while financial institutions

lost about US$48 billion.

Credit card fraud is the most common application of identity theft, followed by phone, utility, bank, real estate rent and other fraud types. Identity theft is costly. On average it costs $1,000 for people to fix the damage to their accounts and, more importantly, restore their reputations. Financial institutions spend about $10,000 per theft victim. The latest wave of identity theft clearly demonstrates that thieves are becoming more aggressive and effective and are shifting their attention from individuals to companies that keep records on large numbers of people. Several large-scale identity theft cases have become public in recent months. Several banks and the identification and credential verification service ChoicePoint have experienced various types of data theft that resulted in customers' personal information getting into the wrong hands. Computer laptops and data tapes with customer information were stolen. ChoicePoint testified before a U.S. Senate committee that it lost several thousand personal records to fraudulent groups posing as legitimate businesses.

Clearly, given the magnitude and financial impact of identity theft, it is not surprising that companies are considering identity theft a significant category within the scope of integrated risk management. Legislation such as California's Senate Bill 1386 is beginning to emerge in recognition of identity theft's impact and to facilitate development of anti-theft programs.

IDENTITY MANAGEMENT AND FINANCIAL SERVICES IN GENERAL AND INSTITUTIONAL FINANCIAL SERVICES IN PARTICULAR

The need to protect information assets and the ability to know and manage who has access to such assets applies to all industry sectors but is especially crucial in financial services. Evidence of the elevated business value of information security in financial services is found in major regulations dealing with financial controls, such as the Gramm-Leach-Bliley Act, the Sarbanes-Oxley Act, the Basel II Accord and the USA PATRIOT Act's Know Your Customer requirements. All require that a financial institution have a board-level information security policy.

While the traditional focus of identity management is the individual, today identity management is a key issue on the institutional side of financial services, particularly in the realm of securities trading. Here the emphasis is on the firm as the source of authority and the individual or an entity as an agent or representative of the firm. The consequences of this difference lie mainly in how an identity management system might be used as the basis of authorization, accountability, and access control systems or services. In the securities industry, for example, an identity being managed may not belong to the individual identified.

More broadly, the identity "issued" by a firm to an employee is not the same identity he or she uses for personal affairs. While the firm may choose, or be required by law or regulation, to give the employee some access to or control over information it keeps, the firm clearly retains the right and responsibility to manage and control the information.

Another difference today is the scope of identity protection. The securities industry views the challenge of protecting identity information to be broader than preventing identity theft. It also includes protecting trade secrets, such as authorized limits to trade, traders' market positions, positions of the firm's clients and portfolio strategy. These "market anonymity" concerns are somewhat specific to the securities industry.

Some of these challenges can be addressed by current-state identity management technologies. Others require additional research and represent emerging areas of interest and activity within identity management.

CUSTOMER IDENTITY MANAGEMENT

Identity management should be extended and enriched to include not just its protection aspect but the relationship management and risk management concerns of today's enterprises and government organizations. This expanded vision of identity management is called customer identity management, or CIM.

CIM helps improve security against internal and external attacks by leveraging the traditional identity management capabilities of access management, entitlement management, provisioning and identity data integration capabilities. CIM assists companies in gaining compliance by providing end-to-end security frameworks and auditable security controls.

CIM also helps maintain customer privacy, while capturing patterns of fraudulent behavior to help protect the enterprise. Where appropriate and within the constraints imposed by customer privacy and opt-out preferences, CIM can support personalization, as well as cross-selling and up-selling of products and services.

CIM recognizes that companies and their customers maintain complex, rich relationships. These relationships often manifest themselves in the scope, breadth and depth of information that companies have on their customers.

To develop personalized, targeted products and services, a company needs to collect and analyze as much customer information as possible. Customers, on the other hand, are willing to reveal just

enough information to get good service but are adamant about protecting the rest. Therefore, companies must recognize that collecting information about customers—without their awareness and sometimes without explicit consent—can easily result in customers feeling that their privacy has been intruded upon, and perhaps privacy laws have been violated. This three-way tension between companies' need to collect information, customers' need for privacy and the requirement to comply with privacy laws and regulations is a driving force behind CIM.

CIM achieves this balance by converging the disciplines of identity management, CRM and risk management to create new integrated processes, data models and architected solutions. These processes, models and solutions are centered on the knowledge and management of identities, entitlements and roles. They also address the policies governing creation and use of identities in order to strictly comply with customers' privacy preferences and regulatory requirements.

CIM SCOPE

Blending identity management, CRM and risk management, CIM is not limited to either side of the enterprise firewall. It covers employees, contractors, partners, customers and prospects alike. CIM offers a broad set of solutions and techniques that address the specific needs of certain users, while treating all identities in an integrated manner.

CIM helps:

- Establish and maintain trusted relationships between companies and their customers and prospects.
- Achieve compliance in the face of growing regulatory requirements.
- Support the security goals of the enterprise.

CIM enriches attributes stored in CRM systems and exposes them according to access policies, customer privacy preferences, and user credentials and entitlements.

The Internet has elevated customer loyalty and retention as business priorities. The notion of customer loyalty is based on a customer's trust that the company will respect his or her privacy preferences and can provide verifiable assurance of customer data confidentiality.

Often, customers are unwilling to disclose or explicitly allow access to information about their relationships, or other personal information, unless and until they feel confident that the information will be protected and used only for the stated purpose of improving service. Violating this confidence often results in damage to, or termination of, the customer's relationship with the company.

CIM addresses the data issues of traditional CRM. Specifically, CIM architecture and technologies focus on a range of customer identity issues:

- Customer data has to be protected from unauthorized or fraudulent use, but it can be compromised.
- Customer data has to include external and internal customer privacy preferences—a new requirement that calls for modifications in existing applications and data models.
- Customer data confidentiality and integrity has to be assured.
- Customer data that meets the USA PATRIOT Act's Know Your Customer and other regulatory requirements must be accurate, timely and complete.
- Customer data access has to be controlled based on corporate policies, authenticated credentials of users and their entitlements.
- Access to all sensitive data including customer data has to be auditable.
- Customer data sharing has to be managed according to corporate data sharing and disclosure policies to mitigate the risk of third-party data compromises.

By accomplishing these goals, CIM contributes to increased productivity, higher customer satisfaction and revenue growth. It expands the capability to deliver personalized products and services and supports greater business agility during events such as mergers and acquisitions.

Incorporating a strong and visible customer privacy program into CIM capabilities can help strengthen customer relationships and loyalty and improve understanding of customers' total relationship with the enterprise.

By focusing on customer data and leveraging applications that use it to deliver business functionality, CIM creates a new value proposition that goes beyond traditional identity management. Specifically, CIM recognizes that consistent complete, protected and timely customer identity data is a key element in successful transformation to an enterprise that is customer-centric and in compliance.

THE CUSTOMER HUB

The CIM framework provides new functional capability that helps companies adopt a customer-centric business model, with the potential to drastically improve the customer experience. This new functionality is known as a federated customer identity store, or customer hub.

A customer hub provides a set of services that consistently aggregate, enrich and reference identity and relationship data by:

- Identifying individuals and creating a persistent, globally unique reference identifier.
- Identifying and managing associations and relationships between individuals.

- Providing data rules to synchronize individual profile data elements across various existing data stores.
- Supporting new value-added business processes such as self-service electronic or digital signatures to eliminate paper-based forms.

CIM can help improve customer experience by:

- Reducing the time required to enroll new customers, a key requirement in high-volatility, high-growth markets.
- Reducing the time required to make new internal customers (employees) productive.
- Capturing and enforcing customer privacy preferences and helping deliver personalized services.
- Improving customer experience by reducing the number of times required for customers and business partners to log into various parts of the enterprise portal.
- Creating a consistent, secure and efficient mechanism to create and reset passwords across multiple systems.
- Providing a reliable and timely vehicle for removing former customers and employees from all systems and revoking associated access privileges.
- Helping leverage central, authoritative user data and entitlements information for new systems development.

CIM can support improved enterprise efficiency by:

- Enhancing security control over identity data and its consumption.
- Establishing a single point of reference for identity from authoritative sources.
- Reducing the time required to make new internal employees and consultants productive.
- Exposing and extending existing identity data and providing ubiquitous interfaces for data access.
- Reducing application development costs and time to market.
- Allowing secure, uniform implementation of data access, functions, internal applications, Web sites and CRM data.
- Concealing the complexity of legacy systems with respect to security and data visibility.
- Enabling the enterprise to maintain control over core assets such as business logic.

CIM ARCHITECTURE AND ENABLING TECHNOLOGIES

The CIM reference architecture is an organizing principle for disparate identity data stores and the individual technologies and processes that manage them. The architecture defines how to manage the flow and consumption of identity data across the enterprise in line with business demands and in concert with information use by CRM and risk management systems.

The CIM reference architecture is one that lends itself to an SOA approach, with four layers:

- **Infrastructure**—directory service, workflow management and data security tools such as public key infrastructure (PKI) and tokens.
- **Access control and management**—authentication, authorization, role-based access control, single sign-on, entitlements, roles and rules repository, audit/reporting and monitoring.
- **Identity provisioning and life cycle management**—provisioning, policy management, customer profile management, customer preference management.
- **Identity federation**—interenterprise identity mapping and provisioning.

The CIM reference architecture reflects the complexity of combining CRM and identity management processes (see Figure 1).

The CIM reference architecture integrates traditional data management processes and components of CRM and analytical systems with new CIM functional components. Each layer relies on the services of the layer below and provides services to the layer above. CIM applies this layered reference framework to define a service-oriented, process-driven, integrated environment.

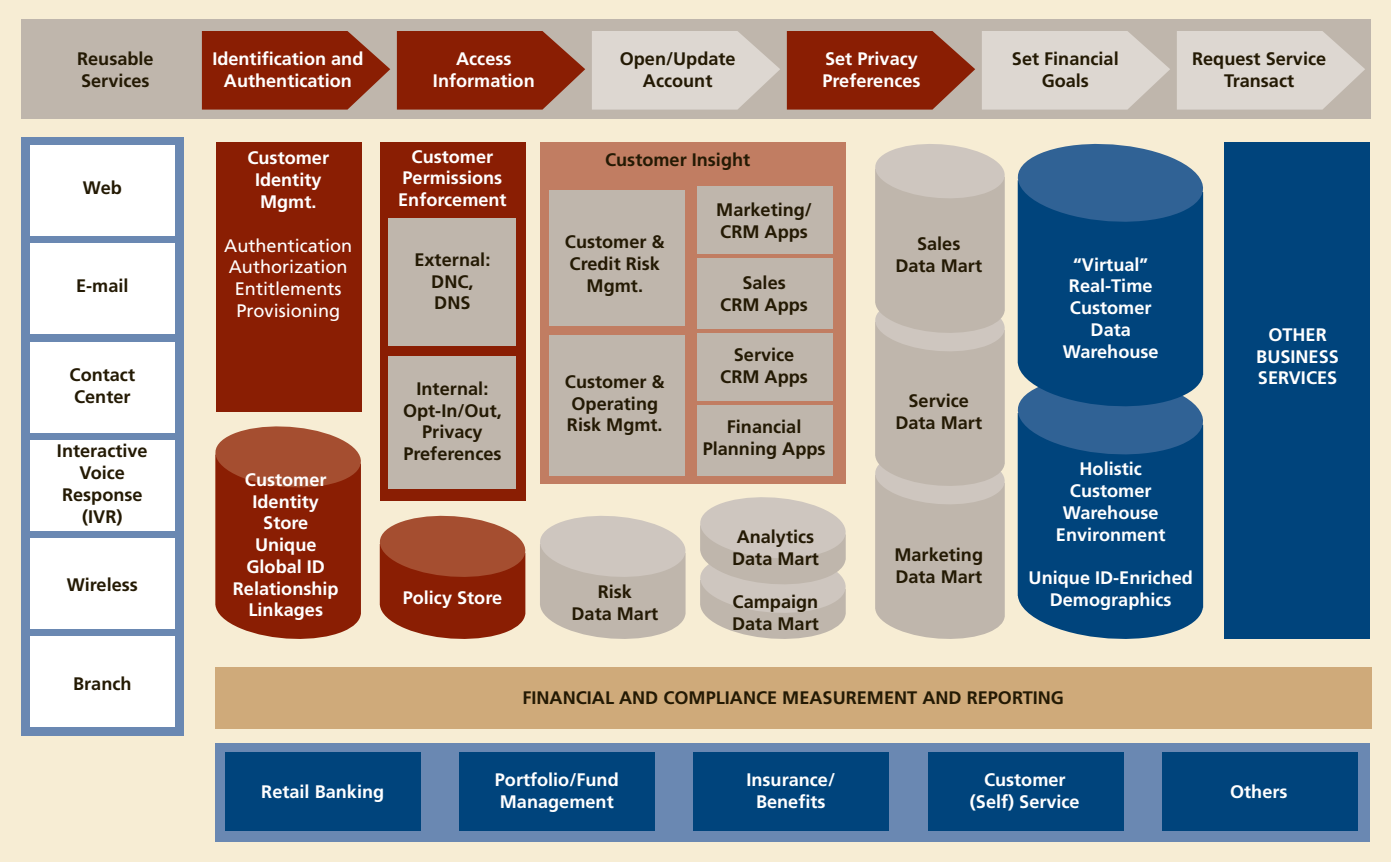
CIM TECHNOLOGIES

CIM, like identity management, has its roots in information security and easily lends itself to digitization. Not surprisingly, a host of core CIM technologies include digitization technologies such as:

- Strong, multifactor authentication using smart cards, tokens and biometrics.
- Authorization, including support for security interoperability standards such as security assertion markup language (SAML), roles-based access control (RBAC) and Web single sign-on (SSO).
- Provisioning and de-provisioning, including creation, distribution and removal of credentials and entitlements.
- Workflow management.
- Identity federation, including support and implementation of emerging schemas such as the Liberty Alliance.
- Directory and meta-directory services.
- Web services and SOA.
- Extensible markup language (XML).
- Information security, including network and perimeter security and encryption.

CIM expands the scope of technologies traditionally associated with identity management by adding:

Figure 1: Customer Information Management Reference Architecture



- Data protection technologies, such as auditable access controls and strong encryption to support compliance with current and emerging data privacy and confidentiality regulations.
- Electronic and digital signatures to help protect data integrity and support the transition to paperless operations and improved customer experience.
- Creation and management of secure activity logs and evidence archives to support legally acceptable nonrepudiation.
- Security policy definitions and management.
- Entitlements, roles and rules engineering.
- Customer data integration.
- Portal technologies.
- Business rules engines.
- Data warehousing.
- Business intelligence.

Combining these numerous, complex technologies in a CIM framework can help organizations create value and improve efficiency.

CONCLUSION: GROWING WITH CIM

CIM is a comprehensive approach to integrating identity management with CRM and risk management systems. Properly deployed, CIM can help companies achieve an encompassing view of customers, relationships and risks, while respecting privacy preferences and complying with regulations.■

IDENTITY MANAGEMENT AND DATA SECURITY: THE LEGAL LANDSCAPE

Regulatory requirements addressing data privacy, confidentiality and integrity include:

Sarbanes-Oxley Act—Requires that company boards and officers know who has access to what information and that proper security controls are in place to ensure data confidentiality and integrity.

Basel II Accord—Establishes advanced approaches to calculating credit risk capital based on internal data and systems.

Gramm-Leach-Bliley Act (GLBA)—Dictates that organizations preserve the security and confidentiality of nonpublic personal information, including personal financial data.

Health Information Portability and Accountability Act (HIPAA)—Directs healthcare providers to preserve the confidentiality of individual medical records.

Children s Online Privacy Protection Act (COPPA)—Establishes privacy protections guidelines for any organization holding information about children.

California Senate Bill 1386 (the California Data Security Act)—Requires that any organization that loses a California citizens personal data must alert its California customers via "notification to major statewide media."

New York Reg. 173—Mandates active encryption of sensitive financial information sent over the Internet.

European Union Data Protection Directive—Establishes rules addressing the handling of all types of personal data, including requirements that personal data must be kept confidential.

Homeland Security Information Sharing Act (HSISA, H.R. 4598)—Establishes security rules and regulations.

International Organization for Standardization (ISO) 17799—Defines an extensive approach to achieving information security, including communications systems requirements for information handling and risk reduction.

Japanese Protection for Personal Information Act—Kojin Joho Hogo HouA, May 2003.

Federal Trade Commission, 16 CFR Part 314—Ensures the security and confidentiality of customer records and information.

12 CFR Part 573 and Securities and Exchange Commission (SEC) Final Rule, Privacy of Consumer Financial Information (Regulation S-P), 17 CFR Part 248 RIN 3235-AH90—Prohibits a financial institution from disclosing nonpublic personal information about a consumer to nonaffiliated third parties.

New Jersey AB2553—A bill under consideration to prohibit companies from displaying or using Social Security numbers.

12 CFR Part 21, Subpart B—Requires reporting of suspicious activities.

12 CFR Part 21, Subpart C—Sets procedures for monitoring Bank Secrecy Act compliance.

17 CFR Part 210—Defines guidelines for records retention.

21 CFR Part 11—Food and Drug Administration (FDA) guidelines governing use of electronic record keeping and electronic signatures.

OCC 2001-47—Rules for the third-party data sharing protection. International Accounting Standards Board's (IASB's) accounting procedures from American Institute of Certified Public Accountants (AICPA) and the Financial Accounting Standards Board (FASB).

SEC, NASD, FDA 21 CFR Part 11—Defines guidelines for trustworthy electronic records.

SEC Final Rule (Regulation S-P), 17 CFR Part 248—Requires privacy of consumer financial information.

How It (Should) All Start

Designing and Implementing a Continuity of Operations Solution for Financial Services Firms

Abstract

As noted in the introductory article of this issue of the Financial Services Technology Journal*, the existence of a comprehensive business continuity or enterprise organizational survival plan can be a way to mitigate operational risk and thus is an element of Basel II. In addition, the need for a good business continuity or enterprise organizational survival plan for compliance systems also now stems from the fact that regulators demand and expect a very short response time when they issue requests for documentation. Many elements must come together for a financial services firm to respond effectively to emergencies, maintain continuity of operations and recover from an event. The Organizational Survival Planning (OSP) model provides the framework for a comprehensive approach to crisis events. Through OSP, firms can set an organizational survival strategic vision and develop comprehensive plans for organizational awareness and training, model crisis communication modeling and address the human factor in crises. Technologists can gain a lot by getting a good understanding of the OSP model, because it encompasses, but also extends much further than, information technology issues.*

THE NEED FOR A COMPLETE, VIABLE SOLUTION

In these times of political, economic and ecological uncertainty, financial services firms face a complex challenge in maintaining continuity of operations. Gone are the days when we took comfort in being able to restore technology infrastructure following a natural disaster. A new reality surrounding potential crisis events is driving many firms to rethink their approach to organizational survival.

The key drivers of this approach include:

- **Exponential changes in the scope, type and frequency of disaster events.** The types of disaster events addressed in business continuity or disaster recovery planning efforts even five years ago are strikingly limited compared with the potential operational impacts most organizations acknowledge as a reality today.
- **The evolution of event-neutral planning.** While financial services organizations do not need to abandon traditional scenario-specific planning where appropriate, it has become virtually impossible to predict and subsequently script a response to each potential disruptive event. There is an ever-increasing need to design an organizational survival program that proactively prepares a company to be effectively reactive in a crisis event.
- **The viability of the program (versus the presence of a plan).** Historically, the audit approach to business continuity and disaster recovery plan evaluation was designed around a "checklist" approach of identifying and verifying plan components. In truth, the "presence of a plan" in no way translates into the "viability of the program." A plan is merely a tool until it is communicated and evangelized throughout the company. Without a high degree of organizational confidence in the plan, it will likely go unused in a crisis event.
- **The interdependencies of organizational processes and resources.** The traditional approach to building plans using a silo approach has proven ineffective in many disaster scenarios. While it is much simpler to design a continuity or recovery plan for an individual application, platform, facility or functional unit than for an entire organization, in reality many of these individual plans will be executed simultaneously in a crisis. Failing to account for the interdependencies of processes and resources properly can have a significant impact on the success of plan execution.
- **Completing the puzzle.** Finding the missing pieces and filling in the gaps is critical. In most financial services organizations, much great work has gone into designing recovery solutions for the technology infrastructure. However, many organizations are finding that other components must also be addressed to ensure survivability. Of course, technology-based resources are vital to operational success and profitability. But, as will be discussed here, there are many other types of resources that also must be protected to maintain true continuity of operations.

Figure 1: Key Success Factor and Foundational Components of the OSP Model

THE ORGANIZATIONAL SURVIVAL PLANNING MODEL

The Organizational Survival Planning (OSP) model is a holistic, viable approach to creating an organizational survival planning capability. The model integrates three vital components:

- The primary key to enterprise survival planning success.
- The three steps to building the OSP foundation.
- The four cornerstones of surviving an actual crisis event.

The primary keys to success and foundational components of the OSP model are shown in Figure 1.

DESIGNING AN OSP STRATEGIC VISION

The old saying "If you don't know where you're going, any road will get you there just fine" has special relevance to organizational survivability. Many firms both within and outside financial services have invested significant resources over the years to address business continuity or disaster recovery. Yet these firms still lack a holistic, viable solution to crisis survivability.

An OSP strategic visioning workshop involves senior management in making the key decisions that will provide the road map for moving the program where it needs to go. Key questions will be answered that will allow a program to be properly scoped. All initiatives will work in tandem to move the program forward to completion.

A visioning workshop should be the first step in moving a company from its current business continuity and organizational survival state to the desired future state. If an OSP strategic vision is not designed, efforts currently under way might be ineffective or even in conflict. The quickest way from point A to point B may or may not be a straight line, but it always helps to know where point B is and what it looks like.

A STEP-BY-STEP APPROACH TO BUILDING AN OSP FOUNDATION

Following are the key steps necessary to build an OSP foundation:

THE OSP FOUNDATION: STEP ONE (Research and Discovery for Continuity of Operations)

The elements shown in gray in Figure 1 represent the research and discovery key foundational elements. These include:

- **Business impact analysis**—Once an OSP strategic vision and road map have been created, performing a robust business impact analysis is often the first step of foundational research required for proper plan and program design and development. The analysis should address the following components:
  - Identification and mapping of organizational business processes.
  - Resources, both technology-based and nontechnology-based, that support the business processes.
  - Interdependencies of processes and resources.
  - Operational impacts, both quantitative and qualitative, on business processes should individual or collective resources be disrupted.
  - Identification of recovery time objectives and maximum allowable downtimes for business processes.
  - Prioritization of both processes and resources for continuity and recovery.

Without complete and accurate prioritization of processes and resources, it becomes almost impossible to develop plans that will work effectively in a disaster event.

- **Risk analysis**—Although the term "risk analysis" can have a distinct meaning in the financial services industry, in the world of continuity of operations there are three key elements:
  - Categorization of potential disaster events by estimated severity and likelihood of occurrence.
  - Identification and mapping of key preventive, detective and reactive controls protecting the vital assets of the organization. Vital assets are resources that support mission-critical business processes.
  - Analysis of the degree of vulnerability of vital assets to high-severity and high-probability events.

A logical follow-up to risk analysis is disaster avoidance planning, or proactive risk mitigation, which is discussed in Step Three.

- **Identification of strategic alternatives for continuity and recovery**—Completing the steps above provides an understanding of the prioritization of processes and resources relative to a disaster event, and the degree of vulnerability surrounding vital operational assets. Armed with that information, it is now possible for a firm to design continuity and recovery solutions that meet or exceed the required recovery time objectives, and select the optimum solution combination based on cost and benefit analysis and the level of risk the organization is willing to accept.

The old saying "If you don't know where you're going, any road will get you there just fine" has special relevance to organizational survivability.

THE OSP FOUNDATION: STEP TWO (Design and Development of Organization Survival Plans)

The elements shown in tan in Figure 1 represent the four major types of plans that must be designed, developed and integrated to ensure effective response in a disaster. The first and second plan types address response and containment of an event, while the third and fourth plan types address recovery from the event. These include:

- **Crisis management plan design and development**—To be effective, an emergency response and crisis management plan must address:
  - Response to life, health and safety issues.
  - Damage mitigation and containment.
  - Damage assessment and measurement.
  - Disaster declaration criteria and protocols.
  - Crisis communications modeling.
  - Coordination with first responders.
  - Coordination with mission-critical process continuity teams.
  - Transition from crisis response to disaster recovery.
- **Mission-critical process continuity plans**—This is perhaps the most often overlooked area in OSP design, because the traditional focus has always been on "recovering from" the event rather than "surviving through" the event. But every financial services organization has some subset of business processes so vital to profitability, brand image and competitive advantage that these processes cannot stop simply because the company is suffering through a disaster. They must continue on, perhaps in a degraded mode, via manual or alternative automated procedures. The mission-critical process continuity plans must be coordinated closely with the emergency response and crisis management plan to efficiently contain a disruptive event and assume recovery procedures as quickly as possible.
- **Disaster recovery plans**—Disaster recovery represents the recovery of technology infrastructure and all related technology components from a disaster event. It is clearly the most evolved area of organizational survival planning in most financial services firms.
- **Business resumption plans**—Business resumption represents the recovery of business operations from a disaster event, addressing all nontechnology-based processes and resources. These resources include, but are not limited to, people, facilities, other interdependent business processes, external vendors and supply chain partners, knowledge capital, physical records, and functional units. In the future, as organizations drive toward a more holistic approach to OSP, and recovery time objectives are defined that include all supporting resources, the distinction between disaster recovery plans and business resumption plans will fade. But for now, disaster recovery will stand alone while it waits for business resumption to catch up in terms of quality and integration.

THE OSP FOUNDATION: STEP THREE (Design and Development of the Organizational Survival Program)

The elements shown in brown in Figure 1 represent the foundational elements vital to turning a plan into a living, breathing program. These program components drive the cultural transformation necessary to design continuity and recovery solutions proactively across the enterprise as opposed to retrofitting them on the back end. These include:

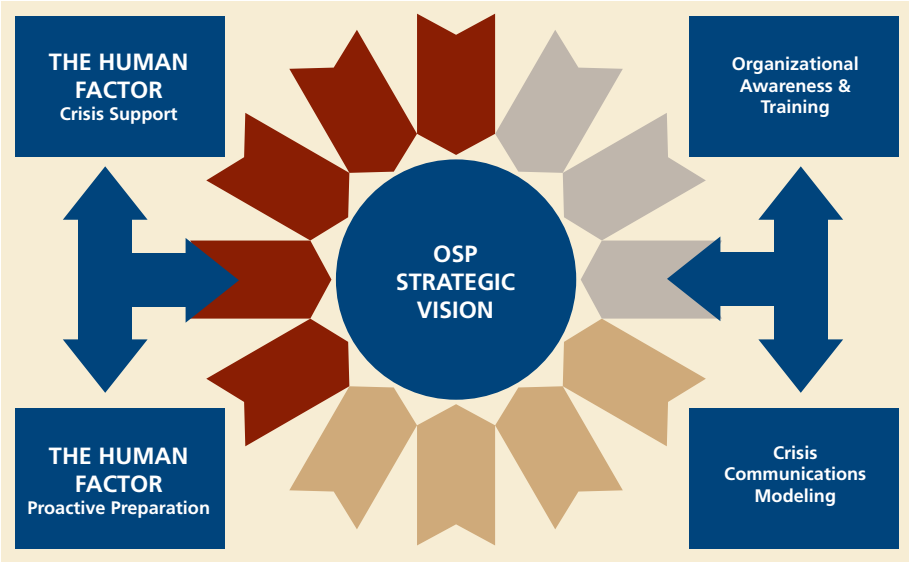
- **Plan and component testing methodology**—Testing and exercising existing plans is the only way to ensure that a) they will actually work in a crisis event, and b) the organization's skill in using the plans will grow along with the level of confidence in the plans as a viable tool for survivability. Testing must address all plan components, not just technology, and should increase in scope and complexity over time.
- **Plan and component maintenance and enhancement protocols**—The maintenance and enhancement of existing plans is perhaps the most complex of all program components. Organizations change rapidly, notably in the case of mergers and acquisitions, and plans must reflect these changes to be usable in a disaster. Identifying plan ownership, designing maintenance procedures, and ensuring quality and consistency across all plans are vital to the success of the overall program.
- **External crisis support planning and testing**—Many financial services firms rely on vendors, external agencies and just-in-time resources to carry them through a crisis event. However, these relationships are rarely tested, and companies often assume that what they need will be there when they need it. This has proven to be a dangerous assumption, and crisis support relationships should be clearly understood and tested against the needs of the organization.
- **Proactive risk mitigation (disaster avoidance planning)**—This program component represents a logical follow-up to completing a risk analysis. It involves designing a control environment that will provide the best distribution of benefits across multiple controls and enhance the existing control environment to reduce the level of risk and vulnerability of vital assets.
- **OSP program office**—Designing a holistic organizational survival program has both project-based components and ongoing activities such as those already identified. The OSP program office should serve as a focal point of control for project-based and ongoing program activities and advance the OSP strategic vision through timely, integrated and viable initiatives.

THE FOUR CORNERSTONES OF SURVIVING A CRISIS EVENT

The four cornerstones of the OSP model are depicted in Figure 2. The model components discussed next require proactive strategy and planning prior to a disaster event. They represent the most common points of failure in an organization's ability to survive a crisis scenario successfully.

- **Organizational awareness and training**—Team-specific training is required for people on response, continuity and recovery teams to help them understand their roles and objectives. Organizational awareness programs provide many benefits both internal and external to the organization, but the primary benefit is to enhance the level of confidence the company has in the OSP program. Well-designed plans have a slim chance of success if adequate training has not been provided to those who will be called upon to execute them in a disaster scenario. This is the third most common point of failure in actual crisis execution.
- **Crisis communications modeling**—A robust crisis communication model identifies what communication needs to take place internally and externally in a crisis event, who will be communicating with whom, how they will be

Figure 2: The OSP Model: The Four Cornerstones of Surviving a Crisis Event



A well-designed plan drives the cultural transformation necessary to design continuity and recovery solutions.

communicating (primary, secondary, tertiary or fail-safe options), when the communication is to take place, and what feedback mechanisms will provide effective communication through the event. This is the second most common point of failure in actual crisis execution.

- **The human factor (proactive preparation)**—People represent the single most common point of failure in a disaster event because of the tremendous impacts an event can have on them physically, mentally and emotionally. Many elements can be addressed by proactively preparing people to survive and recover effectively from a disaster event, including:
  - Identifying special needs, such as medical, physical, dietary, religious and logistics needs, of key response, continuity and recovery team members.
  - Preparing teams for disaster events through team communication and interaction training.
- **The human factor (crisis support)**—Based on the type of disaster event, key personnel may also be dealing with significant personal impacts to themselves, their families and property. To attain the highest performance of personnel available in a crisis, it is imperative to implement both an employee crisis support team and a crisis family support program. These programs provide employees and their families with a high level of confidence that the company will be there to assist them in a crisis scenario.

COMING FULL CIRCLE

There is no "silver bullet" for organizational survival. The reality is that many elements must come together to drive a financial services firm's emergency response, maintain continuity of operations and recover from the event. This is best accomplished by:

- Designing a strategic vision for organizational survival.
- Building a foundation through:
  - Detailed research and discovery relative to continuity of operations.
  - Comprehensive plan design and development integrating the four major plan types.
  - Design of OSP program components and deployment of a viable OSP program office.
  - Proactively addressing the four cornerstones of crisis survival before an actual crisis.

Ignoring these vital elements in the OSP process often creates *a false sense of security* regarding the true probability of surviving a significant disruptive or disaster event. ■

Using Real Options to Mitigate Risks in Large IT Projects

Abstract

In an environment of uncertainty, real option techniques contribute to an understanding of growth options. Such techniques identify how to proceed in the case of initial project success and how best to abandon a project should it become unprofitable. Each information technology investment can be associated with a portfolio of real options. Thus, these techniques offer a valuable tool for evaluating IT investment projects under uncertain conditions. This article outlines an approach to leveraging a strong financial analysis technique, actually pervasive within financial services organizations—real options valuation—to help build solid business cases for IT investments in general and IT implementations in particular, while mitigating the risks associated with those investments.

A NEW URGENCY FOR RISK MODELING

Large-scale information technology projects are both vital and fraught with hazards for financial services firms. IT capabilities must be expanded to meet marketplace, compliance and operations needs. At the same time, more often than not, IT projects deliver less than hoped for outcomes.

According to Robert Glass,[1] issues with planning and estimating are the primary cause of failure in 48 percent of "Software Runaway Projects"—that is, projects that went out of control "because of the difficulty of building the software needed by the system."

Given the challenge in successfully completing IT projects, the ability to evaluate the risk associated with a given project is crucial. A risk evaluation method that can help guide IT investment decisions is the real options approach.

ASSESSING RISK IN IT INVESTMENTS

Consider this situation: The chief information officer of a securities firm wants to implement a new technology architecture to better support risk management and compliance reporting. This new architecture is expected to enable near real-time monitoring of the firm's exposure in several risk domains, such as market risk and client risk, by leveraging advanced application integration architecture. The architecture also will provide a flexible and comprehensive compliance warehouse by leveraging a data warehousing approach.

The project is significant. It affects every IT system within the firm, requires major capital and expense investment, and is expected to take place over several years. After an initial study confirms the scope, amount and duration of the technology architecture investment, the CIO attempts to gain senior management's approval of the project.

Unfortunately, the firm's leadership disagrees with the business case presented by the CIO. The payback period for the investment exceeds two years. And, the return on investment (ROI) is based on assumptions the leaders are not comfortable with, for example, the presumed labor savings associated with developing risk management and compliance reports on the new architecture as opposed to developing similar functionality in the existing environment.

Regardless of their actual purpose, IT investments have a number of common characteristics.

[1] See, for example, *www.ogc.gov.uk/index.asp?id=2261* for an introduction to the IT Infrastructure Library.

Real options valuation helps rethink ROI for IT projects.

The CIO fails to gain approval for the project. The IT organization continues to try and address risk management and compliance reporting by adding ad hoc functionality and specialized software packages to an already complex environment.

Several million dollars later, the organization finds itself supporting too many technology sets, with each point solution usually introducing a new technology. None of the applications are performing as expected. And business users are dissatisfied with risk management and compliance reporting functionality. Product coverage is incomplete, and reporting is not timely.

What went wrong? How can we demonstrate the real value of an IT infrastructure project to firm leadership, when traditional project valuation methods fail to demonstrate that value? How can we make sure the risk associated with such a large project is properly managed, both from a financial and technology perspective?

This article outlines an approach to leveraging a strong financial analysis technique, actually pervasive within financial services organizations—real options valuation—to help build solid business cases for IT investments in general and IT implementations in particular, while mitigating the risks associated with those investments.

KEY FACTORS IN IT INFRASTRUCTURE INVESTMENT

Regardless of their actual purpose, IT investments have a number of common characteristics, including:

- **Linkages to other projects.** IT investments are usually designed to support other projects. Therefore, business cases and ROI analysis for those investments should include those other projects as well. A "project portfolio" evaluation approach works best in this case.
- **Irreversibility of initial investment.** Typically, an IT investment tends to be irreversible. Once an investment is made, it is hard to cancel it and recoup more than a small portion of the initial outlay. IT investments include:
  - People costs, including costs of full-time employees as well as consultants.
  - Hardware and software costs.
- **Risks.** IT investments tend to be risky in nature because of:
  - *Long project duration*—IT investments are typically made to support long-term projects spanning one to three years. Inherently, the payback period on these projects exceeds what most companies are willing to approve.
  - *Unclear ROI*—An IT infrastructure investment does not usually have a clear ROI as a stand-alone project. It may save costs in the long run but does not contribute to top-line goals, such as market share and revenue. Such an investment also is not directly linked to projects that are critical to the business, although it can support them. To show a better ROI, one must take into account the projects that an IT investment supports. This makes the ROI calculation more complex and the business case even more difficult to justify, as the resulting "composite" project—the infrastructure project plus all the other projects it is supporting—will be complex, have a long duration and have a high risk.
  - *Uncertainty of outcome*—IT infrastructure investments usually have difficulty meeting their critical success factors from a business standpoint because their outcome is not directly linked to business projects.
- **Lasting impact on the environment.** IT infrastructure investments may have a high impact on key elements of the IT environment because they pose the risk of disrupting key processes. These risks may include:
  - Impact on software development processes.
  - Impact on operational support.
  - Impact on help desk.
  - Impact on existing application systems.

KEY FACTORS IN IT INFRASTRUCTURE INVESTMENTS FOR RISK, COMPLIANCE AND FINANCIAL REPORTING

Within the universe of IT projects, special considerations affect those projects relating to risk, compliance and financial reporting:

- **Firm deadlines**. IT infrastructure investments that support compliance projects are bound by the same deadlines and constraints as the projects they support. New compliance reports must be implemented under strict deadlines imposed by external regulatory agencies. The associated IT infrastructure project must not be late, increasing the risk associated with the project.
- **Critical impact if project fails**. Regardless of the success or failure of the proposed project, compliance reports must be produced, and risk

must be managed. This factor further increases the risk associated with IT infrastructure initiatives.

- **No direct impact on top-line items.** IT infrastructure projects that support compliance and risk management programs have little or no direct impact on items that matter to senior management, such as increasing revenue profit or market share.
- **Modularity to adapt to multiple risk management and compliance reporting requirements.** Risk management and compliance reporting requirements change over time because of external factors such as new regulatory requirements and changing market conditions. An IT infrastructure project that supports risk management and compliance reporting needs to quickly adapt to changing system requirements, which increases the complexity of the project.

Altogether, considering all these risks, it is almost surprising that any IT infrastructure project is ever undertaken!

THE REAL OPTIONS VALUATION APPROACH IN ACTION

A key issue with most traditional project evaluation approaches is that they treat an IT infrastructure investment as one large project. Once the project is initiated, there is no option to terminate or even change the course of the project without incurring significant costs.

In contrast, the *real options valuation approach* breaks down an IT project, and the projects it is linked to, into a series of smaller projects, with an option to continue or not at the end of each subproject. The idea is to minimize the initial investment and leverage the lessons learned during each project for those that follow.

Real options is an integrated analytical valuation approach used in identifying,

Considering all the risks involved, it's surprising that any IT infrastructure project is ever undertaken.

valuing and justifying strategic corporate investment opportunities that traditional valuation methodologies have difficulty identifying and valuing due to the uncertain nature of cash flow delivery. The real options approach plays an important role in analyzing large, irreversible investment decisions under uncertainty when management has the decision-making flexibility to adapt to changing conditions.

Real options exist in every IT infrastructure portfolio, including the options to exit, abandon, time, switch resources, develop in parallel and pursue strategic growth opportunities. The premise of real options is that future managerial flexibility has strategic value in any IT infrastructure project. Real options analysis attempts to capture and assess the intrinsic value of management's ability to act during infrastructure development.

STEP 1: DECOMPOSING THE PROJECT INTO SMALLER STEPS

In the hypothetical case study presented at the beginning of this article, the following project breakdown can be considered.

- Implement a pilot IT infrastructure that supports the delivery of a small number of compliance reports.
- Extend the pilot IT infrastructure to support the main compliance reports produced by the firm.
- Extend the pilot infrastructure to include a messaging bus to support risk reporting with near real-time information.
- Extend the pilot IT infrastructure to support all risk and compliance reporting requirements.

Note that several alternative project breakdowns could be used, depending on a firm's priorities and the specifics of the IT infrastructure investment being evaluated.

STEP 2: REAL OPTIONS VALUATION

The second step in the process is to perform a real options valuation analysis exercise on the proposed IT infrastructure investment. The five key components of this analysis are:

- Analyze the business case.
- Structure the IT infrastructure analysis in terms of real options.
- Establish the time frame for the exercise of the series of options detailed in the analysis.
- Create and use a dynamic model to analyze the real options in the project.

These steps are denoted 2A to 2D.

STEP 2A: ANALYZING THE BUSINESS CASE, WITH AN EMPHASIS ON DEVELOPING A BASELINE NET PRESENT VALUE

The next step to undertake is similar to using an ROI approach employing discounted future cash flows for the IT infrastructure investment project under consideration, as well as for the projects it is related to.

This includes development of the baseline net present value (NPV) for the project and assessment of the strategic dimensions attached to the project, for example, the projects that would be

enabled by the successful completion of the IT infrastructure project. Using traditional discounting of future cash flows allows us to determine the roots of the project value.

In the initial hypothetical case study, the IT infrastructure project consists of the implementation of a data warehouse and a messaging bus. The projects associated with this investment include:

- Replacing existing compliance reports with a better, more flexible set of reports using a more flexible reporting framework.
- Producing better risk management reports in terms of timeliness and completeness of information used for the reporting.

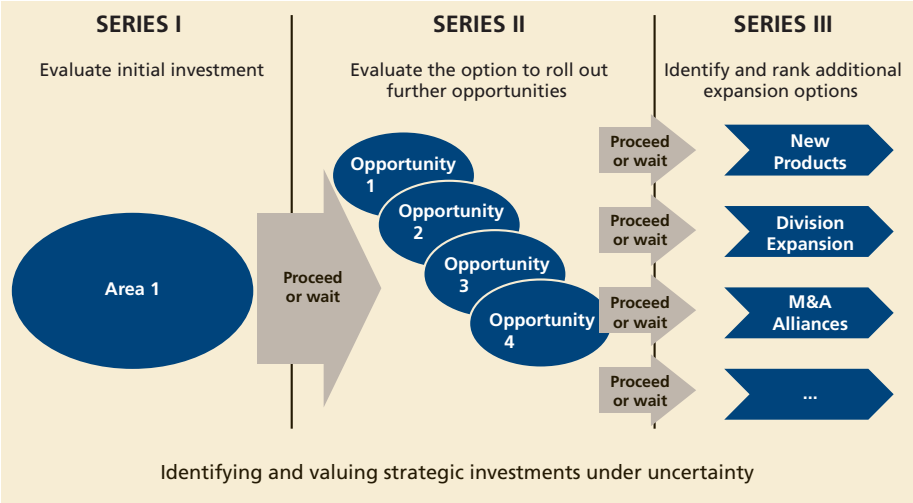
The ROI analysis using discounted future cash flows shows that the project value is associated with the implementation of the new compliance and risk reporting. However, that value cannot be realized until after the IT infrastructure project is completed and the new reports are implemented.

Because of the lengthy time frame associated with this implementation, as well as its associated risks, the business case for the project based on this analysis would be difficult to justify from a financial analysis viewpoint.

In the example, the business case for the IT investment under consideration shows that:

- The cost of the overall IT infrastructure investment, including a full data warehouse and a messaging bus, is US$2 million over nine months, with no direct benefits.
- The cost of producing a full set of compliance reports using the new infrastructure is US$1 million over three months, with expected benefits of $2.5 million.
- The cost of implementing risk reporting with the new infrastructure is $1.5 million over five months, with expected benefits of $3 million.

Figure 1: A Dynamic Optimization Approach



STEP 2B: ADOPTING STRATEGIC REAL OPTIONS THINKING

This step—adopting strategic real options thinking—is key in the analysis. Part of this step is to systematically identify the main groups of future opportunities and their strategic interactions that will be available if the initial project is started.

In other words, which other IT initiatives would benefit from this project? The process to answer this question includes:

- Identification of the main groups of future opportunities and their interactions if the initial project is started.
- Identification of potential implementation options stemming from the start of the initial IT infrastructure project that can subsequently be executed and evaluated through a dynamic optimization approach. Categorization of these options falls into three series (see Figure 1):
  - Series I and II pertains to the initial execution of the IT infrastructure project and the subsequent execution of the immediate options related to this project.
  - Series III pertains to additional options for future optimization, timing and execution.

The options identified in series I and II are qualified, quantified and valued. The options in series III are identified and qualified. The series III options could be categorized into three key groups:

- Options to add new features to the initial IT infrastructure platform.
- Options to extend the initial IT platform to other ranges of services.
- Options to expand the initial IT platform to other lines of business.

In the case study, the following options exist if the decision is made to execute the pilot infrastructure project:

- **Series I**—Implement a pilot IT infrastructure that supports the delivery of a small number of compliance reports, preferably noncritical reports that can be easily produced using the existing infrastructure should the pilot project fail. This pilot IT infrastructure could consist of a small data warehouse, populated by a few batch feeds.
- **Series II**—Extend the pilot IT infrastructure to support the main compliance reports produced by the firm. This involves expanding the data warehouse and its associated batch feeds. Extend the pilot infrastructure to include a messaging bus in order to support risk reporting by providing near real-time information. Leverage this new IT infrastructure to produce a limited number of noncritical risk reports, in addition to the compliance reports.
- **Series III**—Extend the infrastructure to support all risk and compliance reporting requirements and monitoring.

STEP 2C: ESTABLISHING THE TIME FRAME FOR EXERCISING THE THREE SERIES OF OPTIONS

This step involves estimating the time frame associated with each project in the scope of the analysis. In the case study, estimates for the option time frames would be:

- **Series I**—Implement a pilot IT infrastructure that supports the delivery of a small number of compliance reports. The project team believes the project can be delivered in three months.
- **Series II**—Extend the pilot IT infrastructure to support the main compliance reports produced by the firm. The project estimate is three months. Extend the pilot infrastructure to include a messaging bus in order to support risk reporting by providing near real-time information. The project estimate is two months.
- **Series III**—Extend the infrastructure to support all risk and compliance reporting requirements. The project estimate is eight months.

Real options are particularly effective in assessing large, irreversible investment decisions under uncertainty.

STEP 2D: CREATING A DYNAMIC MODEL TO ANALYZE THE REAL OPTIONS IN THE PROJECT

This is the modeling step of the analysis, which leverages techniques similar to those used for financial option modeling using an "option calculator." A number of modeling issues need to be addressed, including:

- **Model selection.** Based on all available data and information obtained above, a modified option-pricing model is used to calculate the options value. Once completed, the calculation of an optimal timing for exercising the option can be determined. When selecting a model, note that a real option behaves like a barrier option.
- **Model computation.** Partial differential equations are used to quantify the results of the model.
- **Model calibration.** Values from stochastic simulations and opportunity cost calculations are used to calibrate the real options model and a predetermined confidence interval. Here is where some judgment is required to, for example, estimate if the log of price returns are indeed normally distributed or to decide what to plug into the model as "standard deviation of investment return."[2] This is where historical data (perhaps even enterprise or industrywide information) is leveraged.

Based on the results from the real options valuation, the strategic value to the initial IT infrastructure project is determined, as well as the optimal trigger value of the options. Real options are particularly effective in assessing large, irreversible investment decisions under uncertainty. For series II and III options, management has the flexibility to reschedule investment to a new opportunity as conditions change. This can be modeled as a real option, where the decision is based on the anticipated discounted cash flow of the opportunity.

Figure 2 shows a representative real options valuation model run on a subset of the initial example, as follows:

- **Project 0 (series I)**—Initial IT infrastructure investment of US$1 million over three months for a simple data warehouse for compliance and risk. A simplified set of compliance reports will replace existing reports if the project is successful. Now assume that investing in Project 0 gives the investor two independent options:
- **Project 1A (series II)**—Investment of US$1 million in development of a full compliance report set, with expected benefits of $2.5 million.
- **Project 2A (series II)**—Investment of US$0.75 million for a messaging bus with simple risk reporting, with expected benefits of $1.5 million.

[2]For an introduction to the barrier option, see *www.riskglossary.com/articles/barrier_option.htm.*

Figure 2: Sample Real Options Valuation Model

Project 0: Initial investment of $1 million over three months (initial data warehouse for compliance/risk) with simple compliance report

ASSUMPTION: INVESTING IN PROJECT 0 GIVES THE INVESTOR TWO INDEPENDENT OPTIONS:

Required Interest Rate	12%
Opportunity Cost	15%
Volatility of Project IA	35%
Volatility of Project IB	35%

Project IA: Investment in compliance report development of $1 million with expected benefits of $2.5 million

Project IB: Investment of a messaging bus with simple risk reporting of $0.75 million with expected benefits of $1.5 million

	t	Actualized Cash Flow	Investment	NPV	ρ	δ	σ	Optimal Trigger Value of Actualized Cash Flow	Actualized Cash Flow	Option Value at t	Actualized Cash Flow	Flexibility Parameter
Options	When (year)	Discounted value of future cash flows	Cost to invest	Discounted cash flows less investment	Required interest rate	Opportu-nity cost	Standard deviation of actualized cash flows	Exercise value	Discounted value of future cash flow		Discounted cash flows less investment	
Project IA	0.25	$2.50	$1.00	$1.50	12%	15%	35%	$1.75	$2.50	$1.72	$1.50	1.75
Project IB	0.25	$1.50	$0.75	$0.75	12%	15%	35%	$1.31	$1.50	$0.77	$0.75	1.75

Figure 3: Sample Results Using Real Option

	Actualized Cash Flow	Investment	NPV	Flexibility Parameter	Final Conditional Option Value at t	Real Option Value at t=0	Decision to Invest
Options	Discounted value of future cash flows	Cost to invest	Discounted cash flows less investment				Decision
Project IA	$2.50	$1.00	$1.50	1.75	$1.50	$1.46	Execute Investment
Project IB	$1.50	$0.75	$0.75	1.75	$0.75	$0.73	Execute Investment

Total Portfolio Value	$2.19

Conclusion: Investing US$1 million in Project 0 gives the investor a portfolio of options valued at $2.14 million.

Once the project team is satisfied that the options calculator has yielded an optimal strategy, it is important to properly communicate the results of running the real options model.

STEP 3: REVIEW AND COMMUNICATION OF RESULTS

This final step in the analysis is perhaps the most critical one—reviewing the results produced by the options calculator and adjusting the model if required.

- **Review the results.** Once the option calculator has been applied, several types of results may prove valuable. It is often useful to compare the total value of the asset using the real options approach with the value that would have been obtained by discounted cash flows. The difference is the value of the options associated with the IT infrastructure investment.
- **Redesign if necessary.** One last question is whether the set of project alternatives should be expanded. Are there ways to create more options by increasing the number of phases or the number of projects? Additional iterations may help refine the strategy.

Once the project team is satisfied that the options calculator has yielded an optimal strategy, it is important to properly communicate the results of running the real options model, as well as the assumptions and parameters used for the model (see Figure 3).

This analysis shows that investing US$1 million in Project 0 gives the investor a portfolio of options valued at US$2.14 million. Therefore, it makes sense to proceed with the initial investment.

CONCLUSION

Real options valuation techniques support the financial valuation of IT infrastructure projects. Among the benefits of such projects are:

- They account for time flexibility.
- They integrate risk elements.
- They complete and improve the traditional valuation.
- They help structure investment policy.
- They allocate capital to investment projects offering the highest potential for value-add.
- They help develop more robust ROI analysis.
- They help manage shareholder value by contributing to understanding of the impact of economic risks and investment decisions.

In an environment of uncertainty, real option techniques contribute to an understanding of growth options. Such techniques identify how to proceed in the case of initial project success and how best to abandon a project should it become unprofitable. Since each IT infrastructure investment can be associated with a portfolio of real options, these techniques offer a valuable tool for evaluating IT investment projects under uncertainty.

Returning to the initial example, using real options valuation techniques would have enabled the CIO to demonstrate to the firm's leadership that the IT infrastructure investment she was proposing had a solid business case, supported by a strong financial analysis, and that risks associated with this investment were properly identified and mitigated.

In addition, she would have been able to present a clear road map for delivering superior risk management and compliance reporting functionality in a holistic manner. A costly and unsuccessful implementation of suboptimal point solutions could have been avoided, and been replaced by a well-integrated, well-implemented system that would have satisfied business users by providing good product coverage and timely reporting. ■

Data for Decision

Monte Carlo Analysis for Technology Project Risk Modeling

Abstract

Estimating the likely cost of an information technology project with many parameters or potential risks is a crucial but difficult exercise. Use of probability-based techniques can facilitate the process, yet many technologists are disinclined to use them. This article provides a quick primer on Monte Carlo analysis (MCA), a technique that provides a visual representation of risk distribution and a practical approach to costing out IT projects. The article draws on real-life examples of applying MCA to large-scale IT implementations and provides a practical approach to using it to cost out IT projects based on real-life case studies, such as the deployment of a new branch network or Voice over Internet Protocol.

INTRODUCTION

Call it the shoemaker's curse affecting technologists. Information technology practitioners in the financial services industry design, deploy and maintain highly sophisticated risk and trading systems, leveraging the most arcane algorithms. Yet when it comes to modeling risk or predicting cost or effort on IT projects, very few technologists are inclined to use probability-based techniques.

Certainly, project management software enables users to conduct sensitivity analysis and run "what-if" scenarios. But varying several simulation parameters manually leads to the kind of combinational explosion that makes exploring more than a very discrete set of changes in assumptions a practical impossibility.

Another article in this issue of the *Journal*, "Using Real Options to Mitigate Risks in Large IT Projects," covers one stochastic approach to decision making that focuses on the opportunity costs and benefits associated with choices made along a given decision tree. Sometimes, though, a simple and quick approach is needed that answers such a question as: What are the chances that the overrun on a project will not exceed 10 percent or 20 percent?

If a cost model includes many parameters, or if several potential risks have been identified, Monte Carlo analysis (MCA) can provide a visual representation of the risk distribution. This article provides a quick primer on MCA and a practical approach to using it to cost out IT projects' risks based on real-life case studies.

The same approach, incidentally, can be applied to benefit analysis to answer such questions as: What are the chances that our return will exceed a given amount? And, the simultaneous use of MCA to analyze costs and benefits will naturally lead to better return on investment (ROI) estimates, something particularly important for organizations that use a Design for Six Sigma approach to project management, in which ROI analysis is a critical part of the "define" phase of the analysis.

AN MCA CASE STUDY

A large bank is looking to refresh its branch network technology. An initial budget has been developed but questions remain as to how some events could adversely impact the overall cost of the project. A systematic analysis of potential issues leads to the building of the table shown in Figure 1.

In this table, each potential hurdle "e" has been broadly identified. The cost of remediation has been assessed and denoted c(e). The probability of this event happening is denoted p(e). Of course, this latter data is subjective information. But in practice it is relatively easy to map concepts such as "very unlikely" to 5 percent, all the way up to "very likely" having a 90 percent chance of occurring. Pairwise comparisons also help fine-tune the model.

A simple, but as we will see ultimately unsatisfactory, way of using this data is to compute the "expected overrun" as the weighted average of costs, using the event

Figure 1: Risks Table

Event ID (e)	Event Description	Examples	Risk Probability p(e)	Estimated Costs c(e)
1	**Time allocated to refresh a branch may vary from the current assumptions**	• No access to the branch (locked, branch manager not present, etc.) at conversion • Have to delay migration due to event (power outage, construction, etc.) • Union issues	5%	**$2MM**
2	**Time allocated to refresh a category 1 type branch completely may vary**	• Same as above	5%	**$0.8MM**
3	**Communications, training, financial tracking and risk management performed by vendors need to be supported by third parties**	• Problems with deployment service provider • Additional resources needed to accelerate deployment rate • Lack of support from internal organizations	50%	**$1.9MM**
4	**New internal pricing model may change the operational cost**	• Product and price guide may impact deployment and operational costs of the branch technologies	25%	**$0.2MM**
5	**Contingency for facility upgrade**	• Refitting of the wiring closet • Refitting of the space itself (expansion of footprint, raised floors, physical security) • Purchase and installation of 19" racks and/or uninterruptible power supply	10%	**$3MM**
6	**Additional cost to acquire the computer telephony integration-related equipment for testing of contact center applications**	• Automatic call distribution systems, interactive voice response systems, voice response units, phone sets, etc. • Additional isolated telecommunication facilities • Load-testing software	25%	**$0.55MM**
7	**Delay in new client associate project may delay the branch refresh**	• If new client associate project is not implemented, then contingency must be provided for refreshing the client associate hardware and for testing and certifying existing teller applications	5%	**$0.8MM**
8	**Delay in operating software release initiative may result in additional costs to test and certify the existing Operating Software Release application (ver 6.0)**	• Remediation of Operating Software Release 6.0	10%	**$0.4MM**
9	**If operating system (OS) decision is not made in timely manner, current licensing agreement will not cover free upgrade to new OS**	• Purchase of OS licenses	25%	**$2.7MM**

Figure 2: Computing the Expected Total Overrun Cost (TOC)

Event Number: e = 1...M (= 9)	1	2	3	4	5	6	7	8	9	Weighted Cost
Risk Probability: p(e)	5%	5%	50%	25%	10%	25%	5%	10%	25%	
Estimated Costs: c(e)	$2.00MM	$0.80MM	$1.90MM	$0.20MM	$3.00MM	$0.55MM	$0.80MM	$0.40MM	$2.70MM	
Expected Cost: p(e) x c(e)	$0.10MM	$0.04MM	$0.95MM	$0.05MM	$0.30MM	$0.14MM	$0.04MM	$0.04MM	$0.68MM	$2.33MM

probability as weight, where the data has been reorganized horizontally (see Figure 2).

This calculation shows that a "likely" overrun would be approximately $2.33 million.

Mathematically, using the notation in Figure 1 and N=9, we have computed an expected total overrun cost (ETOC) in Formula I as:

$$\text{(I)} \quad \text{ETOC} = \sum_{e=1}^{e=N} p(e).c(e)$$

Technically, this is mathematically equivalent, as will be shown later, to saying that there is an even chance the actual cost overrun will be either over or below $2.33 million. But to answer a question such as "What are the chances that the cost overrun will be less than $2 million?" we need another approach. In fact, we need to roll the dice…

USING MONTE CARLO ANALYSIS

In an MCA, one runs a large number of cost simulations assuming that for each run the events that impact the outcome occur randomly but with a preset average frequency. Each individual simulation run provides an outcome in a table, which can be used to plot the expected distribution of outcomes.

Here is the method for computing the outcome of a given simulation run, denoted "r": For each event that impacts the outcome, we randomly decide if the event occurred and then tally up the cost of events, c(r), for this particular run. However, we want to make sure that the way we randomly decide if the event "e" happened for this run is a way that on average reveals event "e" occurring at a p(e) frequency.

To do this, imagine that for each run "r" and event "e" we pick a number between 1 and 100 randomly, denoted $\epsilon_{r,e}$. We compare the number against our p(e) so that if $\epsilon_{r,e}$ is lower than or equal to p(e), we decide that this event occurred for this event during that run. This approach effectively guarantees that, as required, for this run "r" we have decided that the event "e" has occurred in a way that is random, but also is such that our decision technique will guarantee that this event has happened with a probability, p(e), over time, that is, on average for all runs.

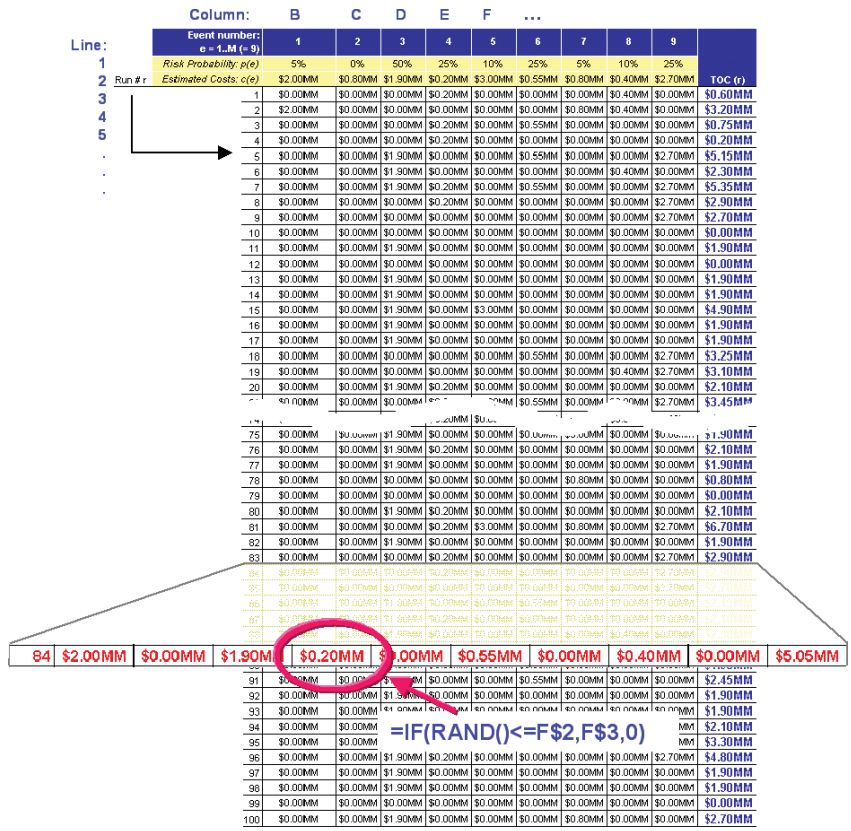
In short, for each run "r" we compute a total overrun cost, denoted TOC(r) in Formula II:

$$\text{(II)} \quad \text{TOC(r)} = \sum_{e=1}^{e=N} [\, p(e) \leq \epsilon_{r,e} \,].c(e)$$

$$[\, p(e) \leq \epsilon_{r,e} \,] = 1 \text{ if } p(e) \leq \epsilon_{r,e}$$

or 0 otherwise

Figure 3: Monte Carlo Analysis Worksheet



Each spreadsheet line represents an individual run. The content and formula of F87 (for run 84) are highlighted. For that cell the function rand() generated a random number lower to 0.1, i.e., 10 percent.

Reflecting the dice metaphor that puts the "Monte Carlo" in Monte Carlo analysis, it's as if we had a dice with one hundred sides and threw it each time to compute each element of the TOC. As daunting as this formula looks, computing this cost for each run is actually easy using a spreadsheet such as that in Figure 3, with each line representing an individual run:

Here is how to read Figure 3: On run 84, we "threw the dice" and decided randomly that events 1, 3, 4, 6 and 8 happened. Adding across all nine columns, the resulting simulated outcome, TOC(84), was $5.05 million.

From there, it's easy to draw a distribution figure providing a summary of results for a substantial number of runs, in this case 100. One counts the number of runs between any two regular intervals within the possible ranges. Figure 4 was obtained by using 20 intervals across the range 0 to $12.97 million in increments of $0.64 million. The maximum amount possible is $12.97 million, assuming that all events happen in one run, that is:

$$\$12.97\text{MM} = \sum_{e} c(e)$$

Finally, the cumulative distribution tells the overall story: Figure 4 shows that there were 29 instances of runs showing a TCO less than or equal to $0.64 million, another four runs in the next interval up to $1.28 million, and none between $1.28 million and $1.92 million. Thus, a total of 33 or 33 percent of the runs were below approximately $2 million, as shown in Figure 5.

Figure 4: Number of Runs (Y-Axis) for Various Levels of TOC (X-Axis)

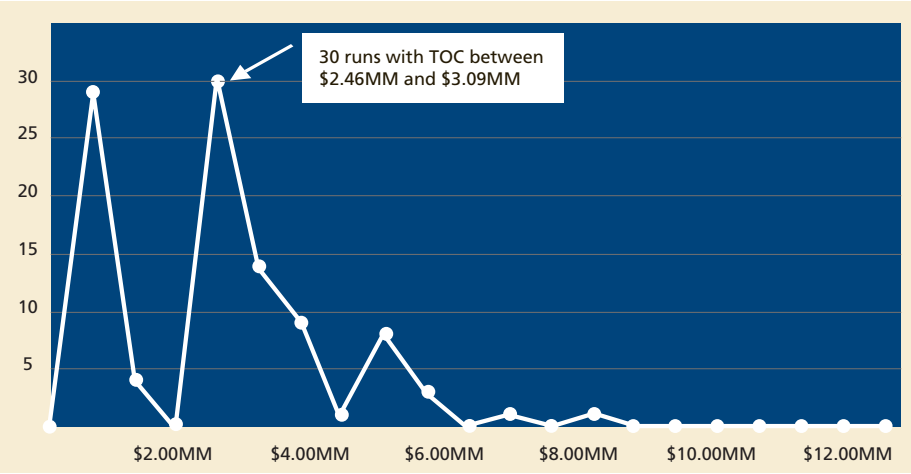
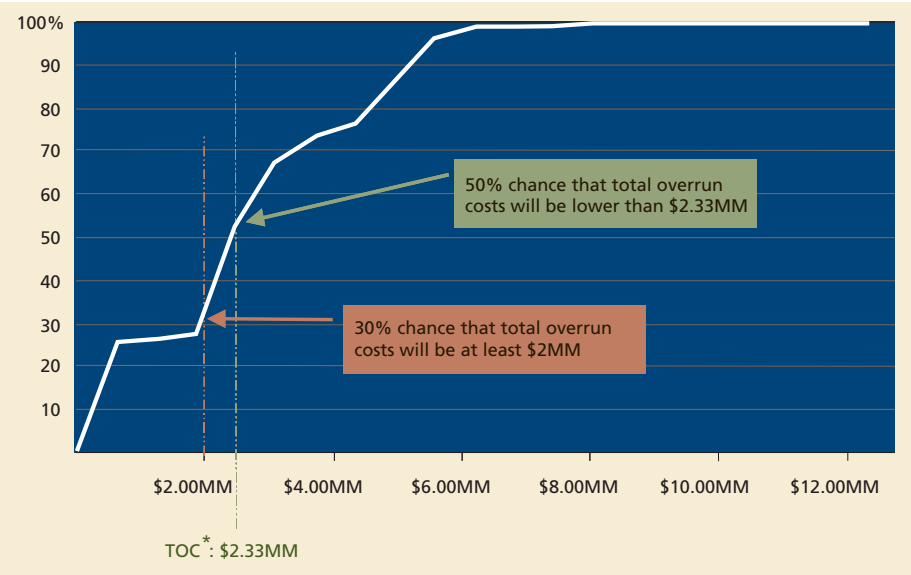


Figure 5: Cumulative Distribution of TOC



IMPLEMENTATION CONSIDERATIONS AND EXTENSIONS

In general, our experience has been that a few hundred runs lead to good results. In practice, this can be verified at least two ways:

- **Convergence of results when the random factors are changed.** If one uses a spreadsheet to implement the model, the TOC distribution curve is actually redrawn every time data is updated or the model is refreshed (by hitting the "F9" key in most implementations). Since the computations are mostly instantaneous, the curve will take several close shapes each time, but qualitatively the overall allure of the curve should be relatively stable in-between refreshes.
- **50 percent chance that cost will be the ETOC.** The overall simulation results should show that TOC has an equal chance to be over or under the ETOC, or the weighted average of

costs. In other words, the ETOC on the x-axis of Figure 5 should map to 50 percent on the y-axis.[1]

MCA can also accommodate situations where each event's cost is defined with a combination of three cost estimates, with obvious notation:

$$(\epsilon_{r,e} \text{ and } \epsilon'_{r,e}):$$

$c_{high}(e)$ (also denoted $c_1(e)$ in Formula III below), $c_{most\text{-}likely}(e) = c_2(e)$ and $c_{low}(e) = c_3(e)$, each with its own respective probability, $p_{high}(e)$ (also denoted $p_1(e)$ in Formula III), $p_{low}(e) = p_1(e)$, $p_{most\text{-}likely}(e) = p_2(e)$ and $p_{low}(e) = p_3(e)$, defined in addition to the probability of the event itself p(e).

In this case, the approach is the same, except the computation of TOC(r) for each run "r" uses the more involved Formula III with the same notation as Formula II. Note that for each run or line and each column in the Excel model, that is for each cell, we now need two independent random variables to produce TOC(r):

$$\text{(III)} \quad TOC(r) = \sum_{e=1}^{e=N} [\, p(e) \leq \epsilon_{r,e} \,].c_{r,e}$$

with

$$c_{r,e} = [\epsilon'_{r,e} \leq p_1(e)].c_1(e) +$$
$$[\, p_1(e) < \epsilon'_{r,e} \leq p_1(e) + p_2(e)].c_2(e) +$$
$$[\, p_1(e) + p_2(e) < \epsilon'_{r,e}].c_3(e)$$

In most cases the various high/low/most likely costs are not event dependent. In others words, we can often say that the most likely cost, $p_{most\text{-}likely}(e)$, is incurred in, for example, a fixed $p^*_{most\text{-}likely} = 60$ percent regardless of the event considered (and with obvious notation, $p^*_{low} = 20$ percent and $p^*_{high} = 20$ percent), leading to a somewhat simplified formula. The approach can be extended for any arbitrary distribution of costs for each event or even by assuming a normal distribution of costs for each event, that is, assuming that each event "e" would follow a cost distribution along a normal curve with an average cost of $m(e)$ and standard deviation of $s(e)$.[2]

MONTE CARLO ANALYSIS IN THE FIELD

The MCA approach has been used successfully with technology projects in a number of areas, particularly in analyzing the cost overrun potential for large infrastructure projects, such as deployment of a new branch network or a Voice over Internet Protocol implementation. In all cases, the MCA model was built on a simple spreadsheet and the results used to define the contingency budgetary line item in the project budget.

MCA also is used in the systems integration realm, although the experience of one financial services firm offers a cautionary tale of the value in employing risk evaluation tools. In this instance, we used a commercial package that leveraged MCA. The firm was conducting a multiyear, global systems consolidation initiative, which it hoped to complete within six months. Halfway through the requirements phase of the project, a Monte Carlo simulation revealed a less than five percent chance that the project could be completed within the time frame the firm had set. Despite the simulation's warning, the firm soldiered on. The project was completed in 16 months.

CONCLUSION

Using Monte Carlo analysis is not new. (The author fondly remembers using it in developing a DOS-based network cost-and-uptime management tool some 20 years ago.) Technologists in financial services have been living with applications that use MCA for complex pricing or risk management tools, yet they rarely use it systematically for budgeting or risk management purposes. It is our hope that this quick primer will help make MCA use for this purpose more pervasive in the future.■

[1]Here is why: Formula II is linear, and, if we average the value of TOC over a great many runs "r," we have (denoting averages by an upper-subscript star):

$$TOC^* = \sum_{e=1}^{e=N} [\, p(e) \leq \epsilon_{r,e} \,]^*.c(e) = \sum_{e=1}^{e=N} p(e).c(e) = ETOC$$

We used the fact that by construction $[\, p(e) \leq \epsilon_{r,e} \,] \xrightarrow{r \to \infty} p(e)$ and the definition of ETOC in Formula I. This means that in Figure 5, the average TOC—that is, the value obtained in 50 percent of the cases on the y-axis—is precisely the value of ETOC on the x-axis.

[2]This exercise is, as is often the case, "left to the reader." You are encouraged to send your version of the formula for TOC(k) for this case to the *Financial Services Technology Journal* editors to receive a subscription to the *Journal* and future mention on its editorial page.

Data Security, Privacy, Integrity and Compliance

Abstract

The Internet has brought about an information and connectivity revolution. Enterprises, governments and individuals all now act as participants in a globally interconnected, networked ecosphere in which all participants originate, process and receive information. The information assets available in this networked ecosphere continue to grow, expanding its scope and increasing security threats. The networked ecosphere and the information it contains have become attractive targets for malicious attacks, information theft and other security threats. Sensitive data needs to be protected from unauthorized access and use. This need is emphasized by a number of regulatory and compliance requirements, some of which are general, others specific to the financial services. This article focuses on the specifics of data security. Security and operational risks and compliance issues are addressed elsewhere in this issue, while a companion article deals more specifically with infrastructure issues related to data security.

THE EVOLUTION OF DATA SECURITY

The Internet has brought about an information and connectivity revolution. Enterprises, governments and individuals all now act as participants in a globally interconnected, networked ecosphere in which all participants originate, process and receive information.

The information assets available in this networked ecosphere continue to grow, expanding its scope. These assets often are aggregated in large data stores and networked storage devices, making them more valuable and accessible.

The networked ecosphere and the information it contains have become attractive targets for malicious attacks, information theft and other security threats. Numerous published reports indicate security incidents are growing at an alarming rate, including a near doubling over the last three years.

Consider the high-profile security breach at BJ's Wholesale Club in March 2004. In that well-publicized case, six million accounts were compromised, leading credit card issuers to seek $16 million in damages—$6 million in actual claims and $10 million in credit card reissuing and monitoring costs.

Now consider the far-reaching cost of a higher-volume breach, one involving perhaps 100 million accounts. The costs would include explicit costs of detecting and recovering from security incidents—including fraud write-offs, legal expenses, investigations, audits and information technology expenses—and operational and implicit costs often associated with lost opportunity, legal liabilities and noncompliance with federal and state regulations. Such an incident could result not only in significant loss of revenue but potential termination of business.

Lessons learned from recent well-publicized cases of security breaches show that such an event can put a serious strain on the trusted relationships between service providers and their customers. Moreover, in the era of ever more elusive customer loyalty, losing customer trust may translate into a direct and persistent loss of revenue.

The networked ecosphere and the information it contains have become attractive targets for malicious attacks, information theft and other security threats.

These incidents are often classified as identity theft, the fastest growing white-collar crime in the United States. Perhaps even more alarming, the sources of these incidents and the resulting security threats are no longer coming exclusively from outside the organization. Disgruntled or irresponsible employees and contractors can easily circumvent traditional perimeter defenses and cause significant, long-lasting damage to organizations, their customers and their reputation. According to published Federal Bureau of Investigations reports, threats

originating inside the firewall account for 50 to 80 percent of security attacks.

The vast majority of information stored in digital form contains sensitive data that is the real target of the security threats just described. This sensitive data includes but is not limited to:

- Customer and patient data.
- Financial transactions.
- Finance and accounting data.
- Human resource data.
- Confidential company performance and planning data.
- Military data.
- Legal data.
- Intellectual property, including design and research data.

Clearly, sensitive data needs to be protected from unauthorized access and use. This need is emphasized by a number of regulatory and compliance requirements, some of which are general, others specific to the financial services.

REGULATORY DRIVERS FOR DATA PROTECTION

Concerns over sensitive data in general and customer data privacy and data security in particular have resulted in a broad range of legislative and regulatory requirements for data security. Failure to comply with these mandates can result in civil and criminal liability. A compendium of rules and regulations with data security implications can be found in the sidebar "Identity Management and Data Security: The Legal Landscape" on page 28.

RISKS OF DATA COMPROMISE

Addressing data security, privacy, integrity and confidentiality issues is no longer optional. Data compromises that violate these requirements can put organizations at several types of risk, including:

Security breaches can put a serious strain on trusted relationships.

- **Reputation risk**—Risk to earnings or revenue arising from negative public opinion.
- **Compliance risk**—Risk in not meeting strong regulations such as the Sarbanes-Oxley Act, the Basel II Accord and the USA PATRIOT Act.
- **Operational and transactional risk**— Risk of direct or indirect loss from inadequate or failed internal processes, people and systems or from external events, including fraud. Data compromise at the enterprise level can increase operational risk because of its potential impact on the stability and availability of systems.
- **Third-party information-sharing risk**—According to the Gramm-Leach-Bliley Act (GLBA) and the Office of the Comptroller of Currency (OCC) 2001-47 regulation, an organization is responsible for data privacy and confidentiality breaches, even if these events happened at or are caused by a third-party data or service provider.

Managing these risks is a focus of data security, which is a key component of identity management and information security. In general, identity management encompasses the technologies and processes that address issues related to digital identities and digital information. Information security addresses the need to protect all forms of information from both internal and external threats.

Effective identity management and data security offer significant benefits to organizations by giving them the ability to:

- Minimize fraud.
- Achieve compliance requirements across existing legislation.
- Minimize legal exposure.
- Increase revenue.
- Improve competitive advantage.
- Increase brand equity.
- Enhance customer retention and loyalty.

DATA SECURITY OVERVIEW

The preceding discussion suggests that data protection is a key business requirement that must be dealt with effectively, efficiently and expeditiously. However, solving the data protection problem is a massive, complex undertaking that requires a holistic view of information security and, in particular, knowledge of identities that can either cause harm or become victims of these new types of crime.

Data security refers to the protection of data from either accidental or unauthorized and intentional viewing, modification, destruction, duplication or disclosure occurring during input, processing, storage, transmission or output operations. The practice of safeguarding data is at the core of an information security discipline and is primarily concerned with:

- **Data privacy and confidentiality**—Information should be assuredly available only to those who rightfully have access to it.
- **Data integrity**—Information should be modified only by those who are authorized to do so via authorized actions.

- **Data availability**—Information should be accessible to those who need it, when they need it.

In the context of data security, the term "data" includes but is not limited to data in databases or files, transactional data, operational policies and procedures, system design, organization policies and procedures, system status, and personnel schedules.

A LAYERED SECURITY FRAMEWORK

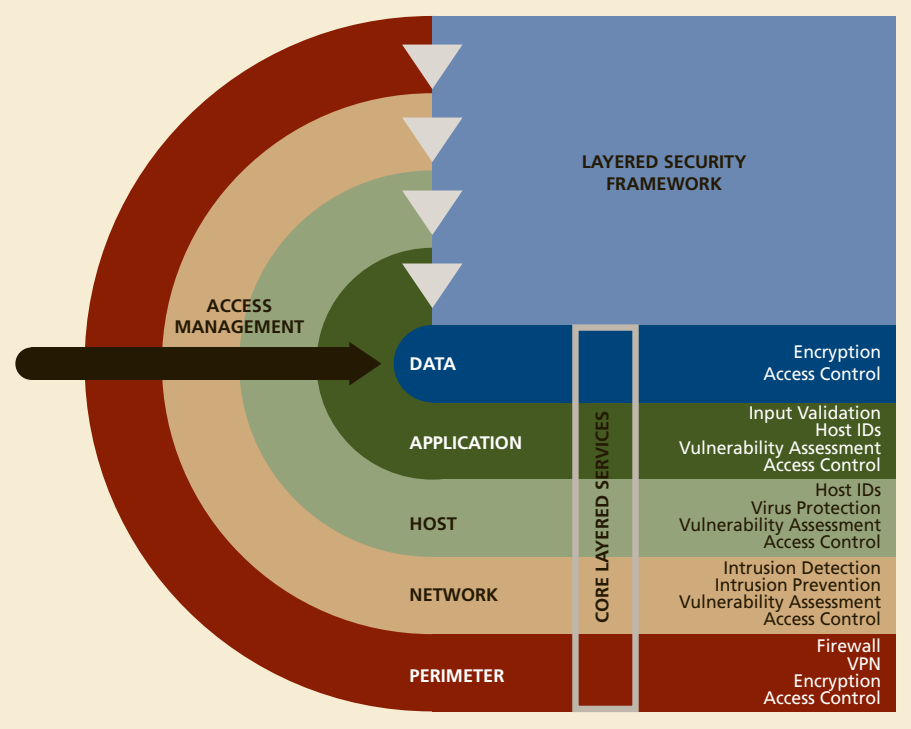
The protection of data can only be effective if considered as part of a comprehensive security strategy that includes an end-to-end security framework. Such a framework considers information as the core that needs to be protected from outside attackers and internal compromises caused by incompetence, lack of appropriate due diligence or malicious intent.

A comprehensive end-to-end security framework offers a multilayered protection approach that surrounds data and its users in an envelope of security controls (see Figure 1). The layered security framework consists of these layers:

- Perimeter
- Network
- Platform (host)
- Application
- Data
- User

Perimeter security deals with security threats that arrive at the enterprise boundary via a network. Perimeter security has to support user authentication, authorization and access control for the resources that reside inside the perimeter. The perimeter may consist of one or more firewalls and a network perimeter demilitarized zone (DMZ) containing Web servers, e-mail gateways, network antivirus protection and domain naming system (DNS) servers exposed to the Internet. It may also implement intrusion detection and intrusion prevention systems.

Figure 1: Core Security Services



Network security deals with authenticating the network user, authorizing access to network resources and protecting information that flows over the network. Network security often uses technologies such as secure socket layer (SSL)/transparent local-area network service (TLS), Internet protocol security (IPSec), public key infrastructure (PKI) and virtual private network (VPN). Network security may also involve implementing intrusion detection and intrusion prevention systems.

Platform/host security deals with the security threats that affect an actual device and make it vulnerable to outside or internal attack. Platform security issues include authentication, authorization and access control, as well as security of the operating system, file system, application server and other computing platform resources that can be broken into or taken over with hostile intent.

Application security deals with the need to protect both access to the application execution environment and the application code itself. Poorly protected applications can provide easy access to confidential data and records. Poorly protected application code can be stolen or modified to create backdoors and insert worms and Trojan horses. Therefore, it is highly important to impose a comprehensive security strategy for each networked application.

Data security includes transactional, historical, dynamic, static and any other types of data that is acquired, stored and manipulated within organizations. This,

obviously, includes software that may represent significant information assets. Generally speaking, security for all data under management falls into two categories: data-in-transit and data-at-rest.

Data-in-transit is defined as any data moving between core systems over network connections, as well as data transferred between applications using store-and-forward queuing mechanisms and transform-load tools.

Data-at-rest is defined as data residing in locally attached and networked data stores and data in archives, such as tape backups.

DATA-IN-TRANSIT SOLUTION CONSIDERATIONS

The techniques and technologies of data-in-transit protection are relatively mature and include already familiar transport layer security, SSL/TLS or IPSec, as well as secure tunneling using VPNs. In cases of proprietary network protocols, for example, IBM Systems Network Architecture APPC/LU6.2, encryption options are available in some implementations. Typically, these protocols are implemented over nonpublic wide-area networks that offer a certain degree of security by design.

The main principles underlying the techniques used for data-in-transit protection include:

- Authentication between the sender and the receiver.
- Encryption of the message payload while it traverses the network fabric.

The advantage of using these data-in-transit techniques include:

- Maturity of the technology solutions.
- Protection of data content while in transit.
- Predictable performance impact.
- Application transparency. As a rule, internetworked applications do not have to be changed to send messages or data over a secure network protocol.

One consideration concerning data-in-transit solutions is the need for client-resident components. For example, in a Web-based environment, SSL/TLS solutions use Web browsers and usually do not require additional client-side software.

IPSec, on the other hand, requires client-side software installation. Since typical legacy environments are not Web-based, IPSec may be the right choice for data-in-transit protection of legacy applications.

Another important consideration is the message-level security that can be layered on top of transport-layer protection. The message payload itself can be protected using a variety of techniques, for example, by using encryption for messages that are moving into and from message queuing systems. Secure e-mail messaging can be implemented using secure multipurpose Internet mail extensions (S/MIME). This feature is available in popular e-mail clients such as Microsoft® Outlook and Outlook Express and does not require additional software distribution.

Protection reach is a key data-protection consideration. Some data-in-transit techniques protect data only between the client and the server, for example, between a browser and a Web server, thus leaving data exposed on sending and receiving systems. To ensure a reasonable degree of data protection, these exposure points require implementation of security measures in addition to out-of-the-box transport level security.

Finally, two key considerations regarding data-in-transit protection should be taken into account:

- Aim to minimize the number of encryption/decryption points to ensure reasonable performance levels, throughput and latency.
- Develop an integrated key management strategy across different network segments, especially if they use different encryption algorithms, such as TLS and IPSec between Web-based networks and legacy.

The protection of data can only be effective if considered as part of a comprehensive security strategy that includes an end-to-end security framework.

Data-in-transit protection addresses some security concerns regarding data that moves over networks. However, by itself this protection is limited and does not address a number of the security concerns discussed here.

For example, a network can be compromised, data payloads can be intercepted or hijacked, data can be replayed or redirected to unintended destinations, and networks can become unavailable or be used for denial-of-service or other types of attacks. Data-in-transit protection is a necessary, but by itself insufficient, approach to protecting data privacy, confidentiality, integrity and availability.

DATA-AT-REST PROTECTION

Even if a network is secure, and appropriate access controls are in place, the sophistication of attackers continues to outpace the ability of defenders to detect and prevent new types of attacks in a timely matter. This can put data and the entire organization at risk.

Therefore, the scope of data security must include an approach that protects

data when all other security controls fail, and an attacker captures data stored on storage devices. Data-at-rest protection aims to address this risk by making data unusable by unauthorized users, even if they have managed to obtain proper network access credentials. Data-at-rest solutions provide a complementary protection capability that works equally to address both external and internal compromise threats.

In general, data-at-rest security technologies rely on authentication, access authorization and control, and payload encryption techniques that can be used to protect all security framework layers. This section looks closely at data-at-rest techniques designed to make data unusable when access controls and perimeter defenses are compromised. These techniques include:

- **Compression**—Data loss protection schemes are often used to provide certain levels of protection while improving the operational throughput of data by reducing record or message length.
- **Encryption**—Data encryption schemes are commonly implemented at the data, application and operating system levels. Almost all schemes involve encryption/decryption keys that all parties accessing the data must have.

When data is at rest on a storage device, these general techniques can be applied at three different levels:

Even if a network is secure, and appropriate access controls are in place, the sophistication of attackers continues to outpace the ability of defenders to detect and prevent new types of attacks in a timely matter.

- The field would be encrypted or scrambled in place. Each sensitive field would be protected individually. The data type and field length would not change. No new fields would need to be added to any files.
- The entire file or database would be encrypted. No differentiation would be made for sensitive versus non-sensitive information.
- The entire device block would be encrypted.

These options must be considered in the context of technical, business and economic requirements dictating the viability of any data-at-rest solution. Key requirements for data-at-rest security include:

- **Support for any form of data**—This includes data at rest, including files, databases and tapes.
- **Total application transparency**—If data is encrypted on a storage device, it has to be decrypted for every access to preserve and even sustain application functionality. Applications that use the data should not be aware of cryptographic operations.
- **Preserved database functionality**—If attributes used for database access are encrypted, such as primary and foreign keys, indexes and search arguments, the database may become unusable.
- **Strong encryption**—This requires the use of standards-based proven encryption algorithms.
- **Key management**—This is a key requirement for any data-at-rest encryption to be viable. For example, key management must address these issues:
  - Encryption/decryption keys must be available to all applications that produce and consume protected data. This is a key data distribution challenge.
  - Keys must change regularly so that the data-protection scheme does not become stale and vulnerable to a brute force attack.
  - Keys must be available for a long period of time so that data can be recovered and used long after it was first encrypted. An example is recovery from archive storage.
- **Performance**—Encryption/decryption operations are computing-cycles intensive and can have drastic impact on the performance of the entire environment.
- **Manageability**—Support for operations, system and network management should be provided.
- **Scalability**—Data-at-rest security solutions should scale up functionally and technically to cover both the current and future data landscapes.

DATA-AT-REST SOLUTION SELECTION CONSIDERATIONS

When choosing a data-at-rest solution, solution capabilities should be evaluated against the requirements above and the business needs of the organization.

First, the solution should focus on protecting the highest-risk areas first, and then be extended to cover other data areas.

The solution choice must address most of the requirements within the domain of the data area at risk. Considerations in choosing a solution may include:

- In general, field-level encryption has the largest negative impact on performance and may affect application transparency.
- Newer operating systems offer file-level encryption, for example, Microsoft's Encrypting File System (EFS).
- Some database management systems

have built-in encryption capabilities.

- Some storage vendors offer proprietary encryption engines that operate on the device to perform encrypt/decrypt operations.
- Some specialized data-at-rest security vendors offer dedicated software and hardware solutions that operate on entire storage subsystems.

While the last three options above offer application transparency and deliver better performance than field-level encryption, they are specific to the data formats and platforms supported. For example, a database encryption will not support protection of nondatabase file structures. EFS is not supported outside Windows®. And built-in crypto-engines only work with the storage device they are built into.

Specialized vendors of data-at-rest solutions differ by technologies, approaches, capabilities, performance and platform support. Many support block-level encryption on the device.

Many vendors offer hardware-based appliances that are installed on the input/output (I/O) channel between the computer and storage subsystem. These appliances deliver the best performance (sometimes less than a 1 percent performance penalty), total application transparency, manageability of devices and simple scalability.

Most current limitations of appliance-based solutions revolve around the types of storage subsystems and the channel protocols used to exchange data between the central processing unit (CPU) and storage resources. Almost all support storage area networks (SANs) and network attached storage (NAS) over fiber channels.

CONCLUSION

The need for data protection has become one of the key priorities of government and commercial organizations—a priority that is driven and reinforced by regulatory and compliance pressures.

Data-at-rest protection is an emerging dimension of data security. It could easily become a competitive differentiator when customers and organizations must be assured that, even if a security breach occurs, the data acquired by such an action continues to be secure. Such confidence in data security can reinforce the trust relationships between organizations and their customers.■

Addressing data security, privacy, integrity and confidentiality issues is no longer optional.

Infrastructure Implications of the Convergence of Risk and Compliance

Abstract

Because the information describing many of an enterprise's business dealings resides within its infrastructure as data, the capabilities of that infrastructure go a long way toward defining the firm's capabilities in the risk and compliance areas. Regulatory agencies increasingly focus on requiring firms to safeguard new data types beyond basic transactions, and safeguarding no longer means only preservation; it also means prevention of inappropriate distribution. Since technology continues to change rapidly, the ability of a firm's infrastructure to preserve data has improved, but the number of ways data can be distributed in an uncontrolled manner is rising. Technologists must address these new challenges in an integrated way. This article focuses on the specifics of data security at the infrastructure level while a companion article[1] deals more specifically with the rest of the data security space.

The Crucial Role of Infrastructure in Risk and Compliance Capability

Companies are expanding their infrastructures to capture, protect and distribute the increasing amounts of data they need to conduct and manage their business. While the upgraded infrastructure and massive data archives they can amass reduce the risk of loss of information and permit data mining activities, they create new operational and compliance issues.

Technology infrastructure has long been a major operational component of financial services firms. It continues to play an expanding risk and compliance role that derives fundamentally from the digitization of increasing amounts of key inputs and processes. At the most basic level, record keeping is now more robust: records are safer from loss or destruction and can be distributed rapidly through the computing, network and storage infrastructures (the "IT infrastructure"). Consequently, firms can now more reliably know such key measures as their credit exposure, often on a real-time basis. In addition, technological innovations allow firms to correlate captured data to increase business value for better customer relationship management and to implement compliance architectures for improved compliance monitoring.

Unfortunately, these expanded capabilities introduce risks along with benefits. Increased risks and new compliance issues follow directly from improved portability and distribution of data as any firm with a hacked database or a lost laptop full of customer data well appreciates.

Increased digitization makes record keeping and monitoring more accurate and efficient, but the proliferation within the infrastructure of tools that transport and manipulate that data make control and reporting more difficult. In addition, the very act of changing the information technology infrastructure to add new capabilities also adds a significant operational risk component.

Financial services organizations digitize inputs and processes because increased protection and distribution have sound business value, but the resulting concentration of data results in an increasing interdependence between operational risk and the IT infrastructure. The failure of that infrastructure can have devastating impact on the firm. Once a firm's processes have been reduced to data, the safeguarding of that data becomes equivalent to safeguarding the firm.

Expanded data/e-mail custodial requirements have a major impact on IT infrastructure.

[1]See "Data Security, Privacy, Integrity and Compliance" by A. Berson in this issue.

THE THREE TYPES OF RISK TO DATA

Operational architects must properly address three types of risk to safeguard enterprise data.

The first risk is that the wrong actors—people or systems—will view or modify the data. Architects counter that **security risk** with authentication systems to assign potential generators or consumers of data to correct roles and with access control systems to ensure that authenticated users act only within their roles.

The second risk is that properly authenticated actors, such as system administrators or software programs, will misuse or damage that data. This type of misuse is the result of software bugs, inadvertent operator error or malicious acts and is actually the major source of technology risk a firm faces. Operators counter that **operational risk** by developing and following sound operational processes.

Finally, the IT infrastructure itself may fail. Data may be lost or become inaccessible due to failure of entire facilities or the computer systems, disk drives and network equipment that comprise the IT infrastructure. Infrastructure architects counter **infrastructure risk** through redundancy of equipment—another router takes over from a failed one—and redundancy of data—copies of data in multiple locations.

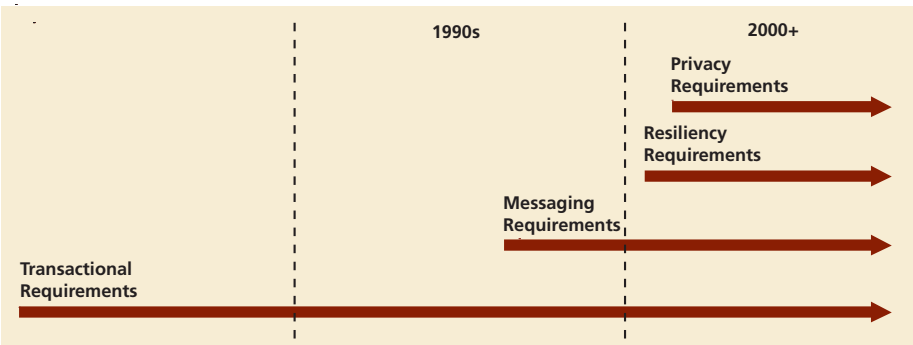
REGULATORY AGENCIES INCREASINGLY FOCUS ON INFRASTRUCTURE

Regulatory bodies impose compliance requirements on financial services firms to ensure that they conduct transactions fairly and report details accurately. Not surprisingly, many IT infrastructure compliance requirements focus on data because that is where the best record of a firm's activities is found. These requirements specify what data to capture, how long to keep it, how carefully to safeguard it, how quickly to report it and when to dispose of it. Other compliance requirements not directly focused on technology operations such as transaction recording generate additional requirements on the IT infrastructure—firms must preserve e-mail to document the background of the execution of business transactions and they must keep this data private. These expanded custodial requirements have a major impact on a firm's IT infrastructure.

So far, regulatory agencies have generally avoided issuing requirements that directly specify the design and operation of IT infrastructure, leaving such issues to the judgment of technologists within the affected firms. Shortly after September 11, 2001, an interagency white paper[2] issued for comment proposed specific technology requirements, such as minimum separation distance between data centers. But, after discussion with the industry, the agencies did not impose these requirements. Rather, agencies have focused on such operational measures as recovery time objective (RTO)[3] and recovery point objective (RPO).[4]

In any event, it is clear that regulatory agencies will expect certain sound practices such as dual (or even triple) data center architectures and will not tolerate a market outage similar in length to that of September 11. Drawing a parallel from the history of the Health Insurance Portability and Accessibility Act (HIPAA), such regulatory initiatives begin with recommendations, proceed to requirements and then add "teeth" in the form of penalties for noncompliance. This

Figure 1: Increasingly Numerous Compliance Types



[2] "Sound Practices to Strengthen the Resilience of the U.S. Financial System," released August 29, 2002. The agencies included The Federal Reserve, the Office of the Comptroller of the Currency, the Securities and Exchange Commission and the New York State Banking Department.

[3] RTO defines how soon data can be made available after an incident.

[4] RPO defines what is acceptable in terms of how much data can be lost through an incident: for example, none, four hour's worth, a day's worth, a month's worth?

These redundant architectures reduce operational risk of failure but raise operational complexity and force radically new and unfamiliar software architectures.

progression is apparent in the operational reliability standard issued by the European Central Bank,[5] which requires (not recommends) two-hour recovery times.

NEW TYPES OF COMPLIANCE REQUIREMENTS

Figure 1 depicts the timing of major compliance trends. It illustrates the increasing frequency of new types of compliance requirements.

Financial services firms have archived and reported transactions for decades—longer than computers have been part of the picture—so such reporting and archiving processes are well designed and robust—any problems reporting transactions relate to correlating existing data.

Other requirements are newer and solutions are less complete and effective, partly because the newer technology has not been "fully baked" and partly because technology groups have not developed the surrounding processes that ensure reliable operation. Two new compliance issues are significant: messaging and privacy:

- Messaging compliance can be quite onerous and expensive. Regulators and litigators want to know as much about the context of business activity as they can, so they are likely to request any message that has ever been digitized, even if it requires firms to save many data haystacks to capture one or two needles. Even for a mid-size enterprise, properly archiving all e-mail messages over several years is very expensive in equipment and operations effort, but the cost of noncompliance is high. E-mail discovery related to litigation has cost some firms tens of millions of dollars in retrieval costs and fines when courts find retrieval efforts inadequate. However, there is more to messaging than e-mail—consider instant messaging—and once all telephone conversations in the enterprise are digitized for Voice over Internet Protocol, regulators may well require that these be recorded as well.
- Privacy compliance is, if anything, even more difficult. Regulations designed to protect the data of individuals are common in the European Union and, driven by California, are becoming more common in the United States. California law SB 1386 requires notification if individuals' data is potentially exposed to unauthorized actors and other California laws restrict sharing data with third parties. As these laws intend, technologists have begun to plug the "data leaks" that allow digitized information to flow outside enterprise boundaries.

TECHNOLOGY CHANGE ALTERS THE IT INFRASTRUCTURE RISK PROFILE

As it has for 30 or more years, technology innovation continues its march up the learning curve. An inevitable result is lower unit costs for components. The availability of cheaper bandwidth, cheaper computing and cheaper storage[6] permits reconfiguring the IT infrastructure to reduce risk in two ways: by adding redundancy and by dispersing computational and (more importantly) storage resources. The rest of this article reviews the most salient and significant examples and associated consequences.

CHEAP BANDWIDTH ENABLES RECONFIGURATION

Cheaper bandwidth permitting high-capacity networking allows infrastructure architects to position major computing and operational resources in locations that are only constrained by the speed of light. As a result, infrastructure architectures are very different today from 10 years ago. Except for special cases,[7] multiple copies of data no longer need to be located in the same room; hundreds of miles can separate them. This reduces the risk that a firm will lose data in a localized catastrophe.

Computer centers need not be located near each other; they also need not be located in the same city as the people they serve, and those that operate the system need not and should not be located in the same country. Remote network access enables enterprises to choose to outsource support organizations—call centers, network operations centers—and move them out of the central data center to third world countries, certainly reducing cost but potentially introducing operational risk, as does data center consolidation.[8]

Outsourced operational groups, to be effective, must be granted significant operational rights: call centers have the ability to reset passwords; network operating centers (NOCs) have the keys to

[5] "Standards for Securities Settlement in the European Union," released September 2004.

[6] Yes, it is cheaper per megabyte; there are just so many more of them!

[7] Synchronous replication that guards against any data loss at all restricts separations to about 100 miles.

[8] For more ways to address these risks associated with data center consolation and ways to mitigate them, see www.bearingpoint.com/datacenter.

The key challenge for reporting on transactions is correlating existing data.

reconfigure key network resources. However, a more important operational risk of outsourcing is that the two organizations often do not have congruent goals. Management by service level is a poor substitute for direct managerial control.

CHEAPER COMPUTING POWER ENABLES REDUNDANCY

Cheaper computing power enables the design and implementation of new, redundant architectures that, for instance, cluster systems so that processing can continue if one system fails. Grid computing spreads computational tasks over many similar systems. These redundant architectures reduce operational risk of failure but raise operational complexity and force radically new and unfamiliar software architectures. New architectures always require a "teething period" in which their idiosyncrasies can be discovered and corrected.

CHEAPER STORAGE ENABLES MORE THOROUGH DATA COLLECTION

More affordable storage solutions provide key benefits:

- **Archiving new types of information.** The cheaper storage becomes per byte stored, the more new types of data can be digitized and archived, and it seems that the principle is "if it's worth digitizing, it's worth archiving." Companies are not only digitizing and archiving data previously recorded on paper, but they are now digitizing and archiving processes down to the phone conversations of participants.
- **Centralizing storage management.** Cheap storage devices make storage arrays possible. In turn, these arrays, coupled with storage area networks, enable data centralization. Once data is centralized, the enterprise does have all its eggs in a digital basket, increasing the payoff for a successful intrusion. But the benefits of central storage centrally managed are great and reduce the risk of data scattered about the enterprise in locations that are not well secured and not well backed up or otherwise protected. If it's all in one basket, at least that basket can be watched.
- **Improving redundancy.** Not only is more data captured but also more copies of that data are made. Storage managers reduce risk by making multiple copies of data to ensure preservation if one copy is lost, but the many copies can increase risk and compliance issues.

NEW INFRASTRUCTURE OPTIONS BRING NEW CHALLENGES

The resulting infrastructure is prone to several downsides:

- **Data inertia.** A modern data center for a large financial data center has hundreds of terabytes of data, a huge storage mass. This mass is hard to move (hence the term "inertia"). Backing this up to any removable media is impractical for recovery purposes, so the value of tape is decreasing except as a last resort. Coupled with continually shortened recovery time objectives, the infrastructure must be designed to never "go down," in short to be "resilient."
- **Data leakage.** In the past, enterprises kept records on paper, later in mainframe systems. While a clerk like Bob Cratchit could write down the names of a few of Scrooge's customers on papers for smuggling out of the office, it was difficult to copy on a large scale. That situation is no more. While transactional information is still kept within databases that are usually mainframe-based, distributed networks ensure that the information is widely distributed as a matter of course and, once outside the corporate data center, is quite difficult to control and safeguard. Currently authorized channels carrying data out of the corporation must be reevaluated; a more daunting task is preventing unauthorized access to global corporate network endpoints such as laptops, personal digital assistants (PDAs) and other communication devices.
- **Data immortality.** Unless very carefully managed by a well-defined and executed information life cycle management methodology, these backup and replication copies can become practically immortal, springing nasty surprises during litigation discovery. Central data stores can be controlled and managed, but the normal information distribution process creates other copies of data: for instance, a customer's account data might be copied to a financial advisor's workstation for review and analysis. As the definition of "workstation" is expanding to include desktops, laptops and even PDAs, these less well-controlled copies pose a risk of compromise of sensitive corporate information or client-specific data if they are misused. It is now possible to use a PDA to reboot a data center server or download facility blueprints or network diagrams. Clearly, such capabilities must be used with care.

Microsoft Outlook ".pst" files are an example of "invisible" copies made as part of the process of distributing e-mail. These offline, workstation-resident, e-mail storage files become filled with e-mail copies for two reasons:

- They are a local, offline storage cache that mobile workers can use to reference e-mail when not connected to

central e-mail servers. There are sound business reasons for supporting mobile computing, but the proliferation of such offline caches is a consequence.

- E-mail storage quotas force workers to save e-mails offline in order to empty inboxes. While storage quotas do reduce storage requirements at the central site, they are a legacy of an era when storage was relatively expensive. Since firms must archive e-mail in any event for compliance reporting reasons, they should investigate the feasibility of installing e-mail management systems that eliminate the need for .pst files as a risk reduction strategy so that this data can be better controlled.

Companies must reexamine the trade-off between the easily calculated cost of equipment and less easily calculated, but significant, cost of not fully purging documents from the enterprise in a timely manner.

GETTING IT DONE—EMERGING SOUND PRACTICES

Infrastructure technologists are developing sound practices that reduce risk and raise compliance.

DATA MANAGEMENT

One class of such practices likely to be effective cluster around data management, specifically, managing the entire data life cycle from end to end. Two approaches are commonly used:

- **Data as commodity.** The first approach treats data as a commodity. We have observed that technologists of a modern financial services firm are responsible for safeguarding a huge amount of data from myriad sources. Given this complexity, it is just not possible to understand fully the significance or retention requirements of every file in the archives. A strategy that treats data as a commodity ensures that all data receives at least a basic level of protection. Examples of commodity strategies include encryption, as well as the various flavors of remote replication. These strategies reduce risk by reducing the likelihood of misuse or loss. However, they don't manage the use of specific data like issues related to retention periods.

Unless very carefully managed, backups and replication copies can be practically immortal, springing nasty surprises during litigation discovery.

- **Data as information.** Other data management strategies being progressively phased in are more granular. They associate metadata either directly or indirectly with the data that must be managed. Indirect metadata includes backup and restore information kept within archiving systems that control the use of offline storage media. Direct metadata includes retention information embedded directly within files that control, for instance, automatic deletion. Retention requirements that include automatic purging are additional drivers to centralized data management. Well-implemented data architectures rely on services provided by the infrastructure to actually implement the capture, manage, deliver and dispose phases of the information life cycle.

RESILIENCY

A second class of emerging best practices focuses on resiliency. As firms drive toward the "five 9's," they can no longer expect to respond to a disaster by moving operations to another data center and flipping a switch. Clustering, load balancing and replication technologies are allowing the creation of a "resilient" IT infrastructure that continues its operation even if degraded by an event. Disaster recovery strategies no longer focus on recovery from failure. Infrastructures should no longer fail; they should degrade.

OPERATIONAL RISK MANAGEMENT

Finally, firms are improving the management of change within the organization using such frameworks as Information Technology Infrastructure Library (ITIL). Technologists are integrating new data management services into existing operational procedures. This integration requires careful design and follow-up to ensure that the new technologies and associated procedures don't interfere with existing, effective processes. Automation is crucial to succeed in reducing the chance of human error.

ADDRESSING THE CHALLENGES AHEAD

Cheaper technology provides opportunities to reduce risk within the organization. While, as already outlined, there are issues, overall, these developments give firms an opportunity to reduce risk and improve compliance responsiveness.

However, there is a gap between understanding the benefits of this new technology and actually realizing them. The challenges exist on at least two levels:

- **Making the return on investment (ROI) is difficult.** Obviously, change costs money. Companies must purchase new devices, configure them with newly written software, install them and run them. Redundancy requires that many components be duplicated, although hot-hot configurations can reduce extra expense somewhat.

  Firms may realize benefits in the end, but those benefits are hard to quantify and the short-term costs are relatively easy to calculate. In addition, many

Figure 2: Drivers Affecting Infrastructure Compliance and Risk Capability

What is new?	What does this mean?	What must be done?
Decreased permissable recovery times	No time to move offline data back online	Increase resiliency, use data vaults for synchronous replication of very short recovery time objective (RTO) data
Inceased data mass	No time to move offline data back online	Increase resiliency, use data vaults for synchronous replication of very short RTO data
Increased privacy requirements	Sensitive data must be secured	Digital rights management techniques, data encryption and other data security techniques
Focus on messaging. Need to retain messages within defined retention periods	Enterprise policies must be created and enforced	Central e-mail management, digital rights management

firms face the economic reality that, while they can relocate personnel relatively cheaply, data centers and their specialized capabilities represent significant facility investments.

Therefore, while organizations can perceive the benefits of technology innovation, amassing the financial resources necessary to realize them can take time. These business constraints slow the adoption of new risk reduction approaches. The real option-based approach to justifying IT infrastructure investment presented in this issue can be used to address this challenge.

- **Change itself introduces risk.** This article has noted elsewhere the relative stability of legacy transaction-based systems compared with newer solutions. Even if new systems are fully unit- and integration-tested (a difficult task in itself), until the supporting staff gains experience with new approaches, the operational consequence of installing them is often poorly understood.

  Integration test scripts depend on the understanding of dependencies on the rest of the IT infrastructure by system stakeholders. Operational cross-checks to uncover issues take time to develop and institute. Therefore, operational considerations are also slow to be adopted but can address the challenge of risk brought about by change itself. The practices are summarized in Figure 2.

CONCLUSION

Technology developments and new operational approaches over this decade have improved infrastructure's resilience and its ability to support compliance requirements. This trend will continue, but new issues will appear, requiring constant reexamination so that infrastructure technologists can continue to support the organization.

To learn more about how our FS solutions can empower your company, Let's Talk. ■

A second class of emerging best practices focuses on resiliency. As firms drive toward the "five 9's," they can no longer expect to respond to a disaster by moving operations to another data center and flipping a switch.

CONTRIBUTORS

Manuel Barbero is the practice leader for the Financial Services Technology Consulting practice in both the Financial Services and Cross-Industry Solutions business units of BearingPoint. He is the executive editor of the *Financial Services Technology Journal* and the panel chair for BearingPoint's Innovation Program.

Daryouche Behboudi is a senior manager with BearingPoint's Financial Services Technology practice. He has managed consulting engagements with top-tier financial services firms, focusing on enterprise network architecture, IT cost takeout, IT strategy articulation, IT operations and organizational design, IT procurement and outsourcing, and project management office and implementation.

Alex Berson is a director and the practice leader of BearingPoint's Customer Identity Management practice. Berson is an active member of industry professional associations, such as IEEE Computer Society and ACM, and standards organizations, including OMG, OASIS and Open Group, and various industry consortia.

Jeff Brashear is a managing director in BearingPoint's Financial Services consulting business. He specializes in large-scale technology projects for global financial institutions.

Tony Castro is a manager in BearingPoint's Financial Services Technology practice. He focuses on strategic planning and architecture in capital markets institutions. He also serves on the steering board of an estimation tool used for modeling large projects.

Julien Courbe is a senior manager in BearingPoint's Financial Services Technology practice. He is responsible for managing a wide range of consulting assignments, with a primary focus on IT strategy, business planning, vendor management and enterprise network engineering. Courbe also leads BearingPoint's Internet Protocol Telephony practice for the financial services industry.

Sean Culbert heads BearingPoint's Global Compliance solutions for the financial services industry. He has assisted organizations such as Goldman Sachs, CIBC World Markets, Citibank and Merrill Lynch, among others.

Paul Dunay is a director with 20 years of marketing strategy experience in delivering positive revenue growth and margin impact. He is currently responsible for leading the Global Financial Services Marketing team for BearingPoint.

Brian Hart is a managing director in the Financial Services Risk and Finance practice. He advises major financial services organizations on risk and finance issues around the world, with a major focus on risk adjusted performance measurement and capital allocation.

Pierre Pureur is a director in BearingPoint's Financial Services Technology practice and the editor of BearingPoint's *Financial Services Technology Journal*. Pureur is a member of the Worldwide Institute of Software Architects.

Gerry Rossi is a senior manager in BearingPoint's Financial Services Technology practice, focusing on the financial services industry.

Steve Timmons, PhD, SPHR, CBCP, is the practice leader for BearingPoint's Enterprise Survival Planning (ESP) practice and a director in BearingPoint's Technology Infrastructure and Integration practice. His experience and interests reside in organizational psychology and development, crisis and emergency management, business continuity planning and human resources consulting.

BEARINGPOINT INSTITUTE *for*

EXECUTIVE INSIGHT

THE BEARINGPOINT INSTITUTE IS A PROFESSIONAL KNOWLEDGE CENTER PROVIDING EXECUTIVES WITH DECISION-MAKING INFORMATION THAT IS CRITICAL TO GLOBAL BUSINESS AND MANAGEMENT ISSUES. THIS KNOWLEDGE WILL BE DRIVEN BY OBJECTIVE THINKING, INDUSTRY LEADERS AND MANAGEMENT CONSULTANCY EXPERTISE.

BearingPoint®

Global Management & Technology Consulting

CONSULTING • SYSTEMS INTEGRATION • MANAGED SERVICES

BEARINGPOINTINSTITUTE.COM

©2005 BearingPoint, Inc. All rights reserved. Printed in the United States.
All trademarks and logos appearing in this document are the property of their respective owners. C3082-FS-1005-02-USRD544